

UNIVERSITÀ DEGLI STUDI DI BARI “ALDO MORO”

DIPARTIMENTO DI INFORMATICA
CORSO DI LAUREA IN INFORMATICA E COMUNICAZIONE DIGITALE

TESI DI LAUREA IN
SICUREZZA INFORMATICA

HONEYPOT: PROPOSIZIONE DI METODI E TECNICHE PER LA THREAT DETECTION

Relatori:

Chiar.mo Prof. Danilo CAIVANO

Dott.ssa Vita Santa BARLETTA

Laureando:

Antonio MONGELLI

Anno Accademico 2024/2025

INDICE

INDICE.....	2
1. CAPITOLO I	5
INTRODUZIONE	5
1.1 ATTACCHI DI RETE.....	7
1.1.1 DoS.....	7
1.1.2 DDoS.....	7
1.1.3 Port Scanning.....	8
1.1.4 Attacchi Web.....	9
1.1.5 Attacchi di Brute force	11
1.1.6 Botnet	12
2. CAPITOLO II	14
STATO DELL'ARTE.....	14
2.1 HONEYPOT.....	14
2.1.1 T-pot	14
2.1.2 OpenCanary.....	18
2.1.3 Modern Honey Network.....	18
2.2 INTRUSION DETECTION SYSTEMS	19
2.2.1 Suricata	20
2.2.2 Snort.....	21
2.2.3 Zeek.....	22
2.3 SIEM	22
2.3.1 Wazuh	24
2.3.2 IBM QRadar.....	28
2.3.3 Splunk.....	29
3. CAPITOLO III	31
IDEAZIONE DELLA SOLUZIONE	31
3.1 PARADIGMA DELLA SOLUZIONE	31
3.2 COMPONENTI TECNOLOGICHE.....	33
3.2.1 Honeypot: T-pot	33
3.2.2 Modello di Machine Learning	33
3.2.3 SIEM: Wazuh.....	33



3.3	FLUSSO LOGICO DEI DATI	34
4.	CAPITOLO IV	35
	MACHINE LEARNING	35
4.1	PREPARAZIONE DEI DATI	36
4.1.1	<i>Dataset.....</i>	36
4.1.2	<i>Feature Engineering.....</i>	38
4.2	ADDESTRAMENTO DEL MODELLO	40
4.2.1	<i>Divisione dei Dati e Strategia di Valutazione.....</i>	40
4.2.2	<i>Addestramento su Dati Sbilanciati</i>	41
4.2.3	<i>Addestramento su Dati Bilanciati</i>	41
4.2.4	<i>Scelta e Addestramento del Classificatore</i>	43
4.3	TEST DEL MODELLO E METRICHE	43
4.4	SPIEGABILITÀ DEL MODELLO (EXPLAINABLE AI).....	47
4.4.1	<i>Analisi dell'Importanza delle Feature</i>	47
4.4.2	<i>Interpretazione delle Differenze tra i Modelli.....</i>	48
4.4.3	<i>Analisi del Comportamento del Modello</i>	49
5.	CAPITOLO V	52
	INTEGRAZIONE DELLE PIATTAFORME.....	52
5.1	CONFIGURAZIONE DEL FLUSSO DI DATI T-POT – WAZUH	52
5.1.1	<i>Deployment</i>	52
5.1.2	<i>Configurazione della Raccolta dei Log.....</i>	53
5.1.3	<i>Configurazione dei Log (Suricata)</i>	53
5.1.4	<i>Configurazione dei Log (Cowrie).....</i>	54
5.2	IMPLEMENTAZIONE DEL MODELLO DI MACHINE LEARNING	54
5.2.1	<i>Monitoraggio e Orchestrazione del Flusso di Lavoro</i>	55
5.2.2	<i>Generazione degli Alert</i>	56
5.3	IMPLEMENTAZIONE DELLA RISPOSTA ATTIVA	57
5.3.1	<i>Ingestione e Normalizzazione degli Alert su Wazuh.</i>	57
5.3.2	<i>Integrazione con il Motore di Analisi di Wazuh.....</i>	58
5.3.3	<i>Automazione della Risposta</i>	59
6.	CAPITOLO VI	60
	CONCLUSIONI	60
	RIFERIMENTI	62





1. CAPITOLO I

Introduzione

Il panorama delle minacce informatiche evolve con sempre maggiore rapidità, e il fallimento nella mitigazione genera perdite economiche per le vittime, oltre a costi infrastrutturali significativi per l'intera rete. Ad esempio, nel secondo semestre 2024 sono stati registrati quasi 8,9 milioni di attacchi DDoS (+12,75 % rispetto alla prima metà dell'anno) ^[1] e nel marzo 2025 si contavano in media 880 eventi al giorno, con punte superiori a 1.600. ^[2]

Negli ultimi anni, gli attacchi DDoS sono cambiati radicalmente:

- Aumento degli attacchi multi-vettore, inclusi HTTP/2, DNS flood, SYN, ACK; ^[2]
- La componente geopolitica emerge attraverso l'uso sistematico di attacchi DDoS per scopi hacktivisti^[3]

Non sono solo i DDoS a rappresentare un pericolo:

- SQL injection costituisce circa il 65 % di tutti gli attacchi Web Application, secondo il rapporto Akamai "State of the Internet" per il periodo novembre 2017-marzo 2019^[4]
- Cross-Site Scripting (XSS) rappresenta circa il 40 % di tutti gli attacchi online nel 2019^[5]
- Brute-force su SSH, FTP e Telnet restano diffusi, specialmente per infrastrutture IoT e server esposti.



Strumenti come Suricata o Snort, basati su firme, rilevano efficacemente attacchi noti, ma faticano con le nuove mutazioni o attacchi zero-day. Varianti evolute, come malware adattivi, possono eludere la rilevazione basata su pattern statici.

È in questo scenario che gli honeypot emergono come strumenti proattivi e complementari: catturando deliberatamente traffico malevolo in ambienti isolati, permettono di raccogliere dati “nel vivo” delle tattiche attaccanti. L’adozione di T-Pot, una piattaforma all-in-one che integra oltre 20 honeypot di diverso tipo, supera i limiti dei singoli honeypot custom, garantendo maggiore scalabilità e varietà di servizi esposti. Tuttavia, anche qui si pongono domande critiche: fino a che punto i servizi simulati riescono a ingannare un avversario sofisticato, e quanto “generalizzabili” sono i pattern di attacco estratti da un ambiente artificiale? Alcuni sostengono che, senza un raffinato livello di emulazione, gli honeypot possano attrarre solo attori “di basso profilo”, mentre per target maggiormente consapevoli la trappola risulta troppo trasparente.

Questa tesi propone un approccio ibrido che integra honeypot, IDS, SIEM e ML per il rilevamento multi-classe di queste tipologie di attacco: DoS, DDoS, Port scanning, Web Attack (XSS, SQLi, Brute force), Brute Force (SSH, Telnet, FTP), Botnet. I modelli ML sono stati addestrati su queste macrocategorie di attacchi per garantire una classificazione robusta.



1.1 Attacchi di rete

1.1.1 DoS

Un attacco Denial of Service (DoS) è una tipologia di attacco volto a rendere indisponibile un servizio di rete, un server o una risorsa informatica agli utenti legittimi, sovraccaricandolo o sfruttando vulnerabilità specifiche. Dal punto di vista tecnico, un attacco DoS può agire a diversi livelli del modello OSI, ma in generale si basa su uno o più dei seguenti meccanismi:

- Saturazione delle risorse di rete o di sistema: l'attaccante invia un volume elevato di traffico o richieste al bersaglio, consumandone larghezza di banda, CPU, memoria o capacità di gestione delle connessioni. Questo provoca rallentamenti o blocchi del servizio, impedendo agli utenti legittimi di accedere o utilizzare il sistema^[6].
- Sfruttamento di vulnerabilità nei protocolli di rete: alcuni attacchi manipolano il funzionamento dei protocolli per esaurire risorse. Ad esempio, il SYN Flood invia richieste di connessione TCP senza completare l'handshake, lasciando connessioni aperte a metà e occupando risorse del server^[7].
- Attacchi a livello applicativo: mirano a sovraccaricare specifiche funzioni o servizi applicativi, come server web, inviando richieste HTTP lente, incomplete o in grande quantità, che consumano risorse senza generare traffico eccessivo. Slowloris è un esempio classico di questo tipo di attacco^[6].

1.1.2 DDoS

Nel caso degli attacchi **Distributed Denial of Service (DDoS)**, la potenza dell'attacco è amplificata dall'uso di una botnet, ovvero una rete di dispositivi infettati da malware (computer, smartphone, dispositivi IoT) controllati da remoto dall'attaccante. Questi dispositivi inviano simultaneamente traffico malevolo al bersaglio, rendendo l'attacco più difficile da bloccare e da attribuire^{[8][6]}.

Le tecniche più comuni di attacco DDoS includono le stesse implementate per gli attacchi DoS analizzate in precedenza.

Dal punto di vista operativo, l'attaccante crea o affitta una botnet, inviando istruzioni da remoto ai dispositivi compromessi che



generano il traffico malevolo. Questo modello consente anche a soggetti senza competenze tecniche approfondite di eseguire attacchi tramite servizi “DDoS-as-a-Service”^[8].

1.1.3 Port Scanning

Il Port Scanning è una tecnica fondamentale utilizzata sia da amministratori di rete per valutare la sicurezza dei sistemi, sia da attaccanti per identificare potenziali punti di ingresso vulnerabili in una rete o in un singolo host. L’obiettivo principale è determinare quali porte di rete sono aperte, chiuse o filtrate, e quindi quali servizi sono attivi e potenzialmente sfruttabili.

Un port scanner invia pacchetti dati specifici a un insieme di porte di un host target e analizza le risposte ricevute. Ogni porta corrisponde a un servizio di rete che verrà classificato come aperta se il servizio è in ascolto e risponde alle richieste, chiusa se non è in uso ma risponde indicando che il servizio non è disponibile, filtrata se non si riceve risposta a causa del filtraggio del traffico di rete da parte di un firewall o di un meccanismo di sicurezza. Questa analisi consente di mappare la superficie di attacco di un sistema, identificando servizi attivi e vulnerabilità potenziali.

Si utilizzano diverse tecniche che variano la modalità di invio del pacchetto e il grado di furtività dello scan.

- TCP Connect Scan: completa l’handshake TCP a tre vie (SYN, SYN-ACK, ACK) per verificare se la porta è aperta. È semplice ma facilmente rilevabile nei log di sistema.
- SYN Scan (half-open scan): invia solo il pacchetto SYN e non completa la connessione, evitando di lasciare tracce evidenti. Se riceve SYN-ACK, la porta è aperta; se riceve RST, è chiusa.
- FIN, Xmas, NULL Scan: inviano pacchetti TCP con flag insoliti o assenti per sondare le porte e bypassare firewall o sistemi IDS. La risposta varia a seconda dello stato della porta e del sistema operativo.
- UDP Scan: invia pacchetti UDP a porte specifiche; la mancanza di risposta può indicare una porta aperta, mentre un messaggio ICMP di porta inaccessibile indica che è chiusa.



- Idle Scan: tecnica avanzata che utilizza un host “zombie” per mascherare l’origine della scansione, rendendo l’attacco praticamente invisibile per il bersaglio.
- Bounce Scan (FTP Bounce): sfrutta vulnerabilità del protocollo FTP per far rimbalzare le richieste di scansione tramite server FTP intermedi, nascondendo così l’indirizzo IP dell’attaccante. [10]

1.1.4 Attacchi Web

Gli attacchi come XSS (Cross-Site Scripting), SQL Injection (SQLi) e Brute force fanno parte di una macrocategoria di minacce chiamata attacchi alle applicazioni web. Questi attacchi mirano a sfruttare vulnerabilità presenti nei software che gestiscono i servizi web, con l’obiettivo di ottenere accesso non autorizzato, manipolare dati o compromettere la sicurezza degli utenti e delle infrastrutture digitali. Sfruttano principalmente l’interazione tra utenti e applicazioni web tramite input non adeguatamente filtrati o protetti, come moduli di login o campi di ricerca, essi in genere hanno come fini il furto di dati sensibili, all’accesso non autorizzato, alla compromissione di sessioni utente o all’interruzione dei servizi.

Il Cross-Site Scripting (XSS) è una vulnerabilità che consente a un attaccante di iniettare script malevoli (solitamente in JavaScript) all’interno di pagine web visualizzate da altri utenti. Questi script vengono eseguiti nel browser della vittima, sfruttando la fiducia che l’utente ripone nel sito web. Abbiamo diverse tipologie di XSS:

- Reflected XSS: Il payload malevolo viene inviato tramite una richiesta (ad esempio, tramite URL) e immediatamente riflesso nella risposta della pagina senza essere memorizzato sul server. L’attaccante induce la vittima a cliccare su un link appositamente creato.
- Stored XSS: Il codice malevolo viene salvato in modo persistente (ad esempio, in un database) e mostrato a tutti gli utenti che visualizzano una determinata pagina (come un commento o un forum).



- **DOM-based XSS:** L'attacco avviene a livello di manipolazione del DOM lato client, senza che il server intervenga direttamente nella vulnerabilità. ^{[11][12]}

La SQL Injection è una tecnica che sfrutta una validazione insufficiente degli input utente per iniettare comandi SQL malevoli nelle query inviate al database. Ciò consente all'attaccante di accedere, modificare o cancellare dati sensibili e, in alcuni casi, di ottenere il controllo totale sul database.

- **In-band SQLi (Classic):** L'attaccante riceve direttamente il risultato della query manipolata nella risposta dell'applicazione (es. errori o dati sensibili).
- **Blind SQLi:** L'attaccante non riceve direttamente l'output, ma deduce le informazioni osservando il comportamento dell'applicazione (es. tempi di risposta o messaggi di errore).
- **Union-based SQLi:** L'attaccante utilizza l'operatore UNION per combinare i risultati di più query e ottenere informazioni da altre tabelle. ^[12]

Un attacco Brute force consiste nel tentare sistematicamente tutte le possibili combinazioni di credenziali (username e password) per ottenere l'accesso non autorizzato a un sistema o a un'applicazione web. Gli attacchi di brute force posso avvenire in diverse modalità:

- **Password Cracking:** L'attaccante utilizza liste di password comuni o tutte le possibili combinazioni per indovinare la password di un account.
- **Dictionary Attack:** Variante del brute force che utilizza un elenco di parole (dizionario) invece di tutte le combinazioni possibili.
- **Credential Stuffing:** Utilizzo di credenziali rubate da altri servizi per tentare l'accesso su più piattaforme. ^[13]



1.1.5 Attacchi di Brute force

Gli attacchi di tipo Brute Force rappresentano una delle minacce più diffuse e persistenti ai servizi di autenticazione remota come SSH, Telnet e FTP. Questi attacchi si basano su un approccio sistematico: l'attaccante tenta tutte le possibili combinazioni di nome utente e password fino a trovare quella corretta, sfruttando la potenza di calcolo e strumenti automatizzati per velocizzare il processo. A differenza di attacchi più sofisticati che sfruttano vulnerabilità specifiche, il brute force si fonda sulla perseveranza e sulla debolezza delle credenziali utilizzate.

Le conseguenze di un attacco riuscito possono essere gravi, come un accesso non autorizzato a sistemi critici, il furto di dati sensibili, la compromissione dell'integrità dei dati e l'utilizzo delle risorse compromesse per ulteriori attività malevole. La semplicità di esecuzione e la possibilità di automatizzare i tentativi rendono questi attacchi una minaccia costante per qualsiasi servizio esposto su Internet.

L'attacco brute force su SSH consiste nell'invio ripetuto di combinazioni di username e password al servizio SSH di un server, fino a trovare una coppia valida. Gli attaccanti utilizzano liste di credenziali comuni o generate automaticamente, spesso sfruttando botnet per aumentare la velocità e la distribuzione degli attacchi.^[14]

FTP è spesso utilizzato per il trasferimento di file tra sistemi, ma la sua autenticazione di base è vulnerabile ai brute force, soprattutto se le password sono deboli o non cambiate. L'attaccante automatizza i tentativi di login, provando numerose combinazioni di credenziali fino a ottenere l'accesso.

Telnet, protocollo storico per l'accesso remoto, è particolarmente vulnerabile agli attacchi brute force poiché trasmette le credenziali in chiaro e spesso rimane abilitato su dispositivi legacy o IoT. L'attaccante tenta ripetutamente di autenticarsi con diverse combinazioni di username e password, sfruttando strumenti come Hydra o script automatizzati



1.1.6 Botnet

Una botnet è una rete di dispositivi informatici compromessi (noti come “bot” o “zombie”), controllati da remoto da un attaccante chiamato “botmaster”. Ogni dispositivo infettato esegue un malware che lo rende parte integrante della botnet, consentendo al botmaster di orchestrare azioni coordinate su larga scala senza il consenso o la consapevolezza degli utenti legittimi.^[15]

La costruzione di una botnet avviene tipicamente in più fasi:

- **Sviluppo e distribuzione del malware:** Il botmaster sviluppa un malware dotato di capacità di evasione e controllo remoto, progettato per infettare il maggior numero possibile di dispositivi.
- **Infezione:** Il malware viene diffuso tramite campagne di phishing, vulnerabilità software, download malevoli o altre tecniche di ingegneria sociale.
- **Comando e controllo (C&C):** I dispositivi infetti stabiliscono una connessione con il server di comando e controllo, attraverso il quale ricevono istruzioni dal botmaster.
- **Attivazione e attacco:** Il botmaster può impartire comandi a tutti i bot simultaneamente, coordinando attacchi mirati o attività fraudolente.
- **Adattamento e persistenza:** Le botnet moderne sono in grado di modificare il proprio comportamento per evitare la rilevazione, ad esempio cambiando periodicamente i server C&C o utilizzando tecniche di cifratura del traffico.

Le botnet sono estremamente versatili e possono essere impiegate per una vasta gamma di attività malevole, tra cui Distributed Denial of Service (DDoS) dove le botnet generano un enorme volume di traffico verso un bersaglio (server, sito web, infrastruttura di rete) con l'obiettivo di saturarne le risorse e renderlo inaccessibile agli utenti legittimi, questo è tra i più comuni e devastanti, spesso utilizzati per estorsione o sabotaggio. Per il brute forcing, utilizzando la potenza computazionale distribuita, le botnet possono automatizzare tentativi sistematici di accesso a servizi online (come SSH, FTP, portali web) provando milioni di combinazioni di credenziali in tempi molto ridotti. Spam e Phishing



dove vengono inviati grandi volumi di e-mail di spam o phishing, veicolando malware, truffe o esfiltrando dati sensibili, queste campagne sfruttano la reputazione di dispositivi compromessi per eludere i filtri antispam. Nel Furto di dati e spionaggio sono progettate per raccogliere informazioni sensibili dai dispositivi infetti, come credenziali, dati bancari o documenti riservati, e inviarle ai server del botmaster, ma anche per Click fraud e cryptojacking, qui le botnet possono essere utilizzate per generare clic fraudolenti su pubblicità online o per sfruttare la potenza di calcolo dei dispositivi infetti per il mining di criptovalute, spesso senza che l'utente se ne accorga.^{[15][16]}



2. CAPITOLO II

Stato dell'arte

2.1 Honeypot

Nel panorama della sicurezza informatica, gli honeypot sono sistemi esca volutamente vulnerabili, progettati per attrarre e intrappolare gli aggressori. In questo modo, i team di sicurezza possono osservare le loro tattiche, tecniche e procedure (TTP) e raccogliere preziose informazioni sulle minacce. Questi sistemi fittizi sono cruciali per il rilevamento precoce degli attacchi, l'accumulo di intelligence sulle minacce e per deviare gli aggressori dalle risorse aziendali reali. Gli honeypot, se ben configurati, generano un basso tasso di falsi positivi, facilitando l'identificazione di attività dannose.

L'evoluzione delle minacce informatiche, con attacchi sempre più sofisticati, rende indispensabile l'uso di strumenti avanzati come gli honeypot per comprendere il comportamento degli aggressori e migliorare la sicurezza. Mentre le misure tradizionali si concentrano sulla prevenzione, gli honeypot offrono un approccio proattivo, fornendo un ambiente controllato per osservare gli attacchi in azione. ^[17]

Di seguito, un'analisi di tre sistemi honeypot open source molto diffusi: T-pot, OpenCanary e Modern Honey Network (MHN).

2.1.1 T-pot

T-pot è una piattaforma honeypot “all-in-one”, multi-architettura e distribuibile, che supporta oltre 20 honeypot diversi contemporaneamente. Offre flessibilità con installazioni



standalone o configurazioni distribuite con nodi “Hive” e “Sensor”. La piattaforma si basa su Docker e Docker Compose per la gestione dei suoi honeypot e strumenti di supporto, garantendo isolamento e amministrazione semplificata. T-pot è costruito su Debian Linux e offre varie edizioni preconfigurate (Standard, Hive, Sensor, Industrial, Collector, NextGen e Medical) a seconda degli obiettivi.

L'architettura di T-pot, basata sulla containerizzazione e su molteplici opzioni di distribuzione, offre una soluzione adattabile e scalabile per implementare un ambiente honeypot diversificato. Docker, in particolare, semplifica la gestione di numerosi servizi honeypot simultaneamente. ^[18]

Docker e Docker Compose sono essenziali per il funzionamento di T-pot, permettendo un'implementazione efficiente degli honeypot e degli strumenti correlati. L'Elastic Stack (Elasticsearch, Logstash, Kibana) è integrato per la registrazione, l'indicizzazione e la visualizzazione degli eventi di sicurezza. ^[18]

T-pot include un'ampia selezione di demoni honeypot, tra cui:

- Cowrie: per emulare servizi SSH e Telnet e catturare attacchi di forza bruta.
- Dionaea: per catturare malware che colpiscono protocolli come SMB, HTTP e FTP.
- Elasticpot: per simulare server Elasticsearch vulnerabili.
- Heralding: per emulare vari servizi di rete.
- Mailoney: per catturare tentativi di spam e phishing via SMTP.
- Snare/Tanner: per rilevare attacchi contro applicazioni web.
- Conpot e Medpot: per sistemi ICS/SCADA e dispositivi medici rispettivamente.

Oltre agli honeypot, T-pot integra strumenti di analisi come **Suricata** un IDS/IPS (Intrusion Detection System/Intrusion Prevention System). ^[18]



Fatt, uno strumento utilizzato per l'estrazione e la gestione di metadati di rete, particolarmente rilevante nell'ambito della cooperazione e interoperabilità tra sistemi informativi distribuiti. I metadati, in questo contesto, rappresentano informazioni strutturate che descrivono le risorse di rete, facilitandone l'identificazione, l'accesso e la condivisione in ambienti complessi e multidisciplinari. Fatt supporta la creazione di archivi digitali interoperabili, permettendo di collegare e interrogare risorse eterogenee attraverso formati elettronici e regole di catalogazione condivise. Questo approccio consente di superare le barriere dovute a diverse modalità di conservazione e pubblicazione dei dati, favorendo la realizzazione di sistemi di ricerca integrati e potenti, utili anche in ambiti come la bibliografia e gli studi storici. In sintesi, Fatt facilita la raccolta, l'organizzazione e la condivisione di metadati di rete, promuovendo l'interoperabilità e la cooperazione tra istituzioni e sistemi informativi, elemento cruciale per la gestione efficiente e la scoperta delle risorse digitali in rete.

[18] [19]

P0f è uno strumento open source specializzato nel fingerprinting passivo dei sistemi operativi, ovvero nell'identificazione del sistema operativo di una macchina remota analizzando il traffico di rete esistente senza inviare pacchetti attivi o provocare interazioni dirette con il bersaglio, a differenza del fingerprinting attivo, che invia pacchetti malformati per stimolare risposte specifiche (come fa ad esempio nmap), il fingerprinting passivo di p0f si basa sull'osservazione delle caratteristiche intrinseche dei pacchetti TCP/IP che transitano naturalmente sulla rete, come il Time To Live (TTL), il Type of Service (TOS), il flag Don't Fragment (DF) e la dimensione della finestra TCP (Win). Questi parametri, combinati con un database di firme, permettono a p0f di dedurre con buona precisione il sistema operativo in uso, la presenza di firewall o sistemi di mascheramento, la distanza del sistema remoto (in termini di hop), il tempo di attività (uptime) e persino il tipo di connessione di rete e l'ISP utilizzato. [20]

Spiderfoot è uno strumento open source progettato per automatizzare la raccolta e l'analisi di informazioni pubblicamente disponibili (OSINT) su un determinato target, facilitando così la fase di reconnaissance nei penetration test o nelle attività di sicurezza



informatica. Sviluppato da Steve Micallef, SpiderFoot integra oltre cento moduli che interrogano un'ampia gamma di fonti, tra cui motori di ricerca, social network, database DNS, registri di indirizzi IP, blacklist di spammer e botnet, e molto altro. Questa capacità di aggregare dati eterogenei in un'unica piattaforma consente di costruire profili dettagliati di domini, indirizzi IP, e-mail, server e persino informazioni geografiche e di proprietà. Il funzionamento di SpiderFoot è altamente modulare e personalizzabile: l'utente specifica il target e seleziona i moduli da eseguire, dopodiché il tool esegue automaticamente le query necessarie, raccogliendo e correlando i dati in tempo reale. I risultati, salvati in un database SQLite, possono essere visualizzati tramite un'interfaccia web intuitiva o esportati in formati come CSV per analisi successive. Tra le funzionalità avanzate vi sono il controllo della presenza del target in blacklist pubbliche, il rilevamento di servizi esposti su internet con relative vulnerabilità (come plugin o moduli obsoleti), e il monitoraggio di IP sospetti associati a spammer o botnet. [21]

[22]

CyberChef è un'applicazione web open source sviluppata dal GCHQ, l'agenzia britannica per la sicurezza nazionale, che funge da vero e proprio "coltellino svizzero" per la cyber intelligence e la sicurezza informatica. Progettato per funzionare interamente lato client nel browser, CyberChef permette di manipolare, analizzare e trasformare dati grezzi attraverso un'interfaccia intuitiva basata sul drag-and-drop, senza necessità di competenze avanzate di programmazione o installazioni complesse. Il suo funzionamento si basa sulla creazione di "ricette", ovvero sequenze modulari di operazioni che possono includere decodifiche (come Base64, URL encoding), crittografia e decrittografia (AES, DES, Blowfish), hashing (SHA-256, MD5), compressione, conversioni di formati, analisi di dati binari e molto altro. Queste ricette consentono di eseguire trasformazioni complesse in modo semplice e ripetibile, con la possibilità di visualizzare i risultati in tempo reale e di salvare o esportare gli output per ulteriori analisi. Questa vasta integrazione di honeypot e strumenti di analisi crea un ambiente ricco per la ricerca sulle minacce. La diversità degli honeypot permette di attrarre un ampio spettro di vettori di attacco, mentre gli strumenti di analisi consentono un'indagine immediata. [23]



2.1.2 OpenCanary

OpenCanary è un sistema honeypot leggero e a basso consumo di risorse, focalizzato sulla semplicità e facilità d'uso per il rilevamento delle minacce. La sua architettura modulare permette di abilitare solo i servizi necessari, minimizzando il consumo di risorse. Scritto in Python, è compatibile con diverse piattaforme e può essere eseguito su vari sistemi operativi. Il suo scopo è generare avvisi chiari e concisi al rilevamento di attività dannose, funzionando come un sistema di allarme rapido. L'architettura di OpenCanary privilegia l'efficienza e il rilevamento mirato, rendendolo ideale per ambienti con risorse limitate. L'approccio modulare garantisce che vengano eseguiti solo i servizi necessari, riducendo l'impronta del sistema e la potenziale superficie di attacco. Il sistema è progettato per essere estensibile, consentendo agli utenti di sviluppare e integrare moduli personalizzati per soddisfare requisiti specifici di honeypot o emulare servizi unici. Rispetto a sistemi honeypot più completi come T-pot, OpenCanary non offre lo stesso livello di inganno o interazione con gli aggressori, limitando potenzialmente la profondità dell'intelligence sulle minacce raccolta.^[24]

2.1.3 Modern Honey Network

Modern Honey Network (MHN) si caratterizza per il suo approccio di gestione centralizzata, offrendo una piattaforma per distribuire e gestire più honeypot da un'unica interfaccia web. La sua architettura semplifica l'amministrazione di reti di honeypot distribuite e su larga scala. L'interfaccia web permette di configurare, monitorare e analizzare facilmente le implementazioni. Il framework supporta diverse tecnologie honeypot per attrarre vari tipi di attacchi.

MHN è costruito in Python e con il framework web Django. Supporta demoni honeypot popolari come Dionaea, Kippo (per attacchi SSH) e Glastopf (per vulnerabilità di applicazioni web). Utilizza MongoDB come database principale e Celery per l'elaborazione asincrona delle attività.

La caratteristica principale è l'interfaccia web centralizzata per la gestione e il monitoraggio degli honeypot. Offre la capacità di



distribuire e controllare vari tipi di honeypot da un'unica piattaforma e l'integrazione con l'intelligence sulle minacce per un'analisi avanzata.^[25]

2.2 Intrusion Detection Systems

Un Intrusion Detection System (IDS) è un sistema progettato per monitorare e analizzare il traffico di rete o le attività su host al fine di individuare comportamenti anomali, attività sospette o tentativi di intrusione che possano compromettere la sicurezza di un'infrastruttura informatica. Gli IDS sono strumenti fondamentali per la difesa proattiva delle reti e dei sistemi, in quanto consentono di rilevare attacchi noti e sconosciuti, fornendo avvisi tempestivi ai responsabili della sicurezza.^{[26] [28]}

Un IDS opera attraverso la raccolta di dati da una o più fonti (traffico di rete, log di sistema, file di configurazione) e l'analisi di tali dati per identificare pattern, firme di attacco o anomalie rispetto al comportamento atteso. Quando viene rilevata un'attività sospetta, il sistema genera un allarme che può essere gestito manualmente dagli operatori o, in alcuni casi, automaticamente da altri sistemi di sicurezza.^{[26] [28]}

Le componenti principali di un IDS sono:

- **Sensori:** raccolgono dati dalla rete o dagli host.
- **Motore di analisi:** elabora i dati e identifica le possibili intrusioni.
- **Console di gestione:** consente agli operatori di monitorare gli eventi e configurare il sistema.
- **Database delle regole/firme:** contiene le informazioni necessarie per riconoscere minacce note o comportamenti anomali.

Gli IDS possono essere classificati secondo diversi criteri, principalmente in base al punto di monitoraggio e alla metodologia di rilevamento. Per quanto concerne il punto di monitoraggio:

- **Network-based IDS (NIDS):** monitorano il traffico di rete in tempo reale, analizzando i pacchetti che transitano su segmenti strategici della rete. Sono efficaci nell'individuare attacchi che si propagano



attraverso la rete e possono identificare attività malevole su più host

- **Host-based IDS (HIDS)**: sono installati direttamente su singoli dispositivi (server, workstation) e monitorano le attività locali come accessi ai file, modifiche ai log di sistema e processi in esecuzione
- **Protocol-based IDS (PIDS)**: monitorano e analizzano specifici protocolli di comunicazione (ad esempio HTTP, FTP) tra client e server, rilevando anomalie o violazioni nelle interazioni protocol-based
- **Application Protocol-based IDS (APIDS)**: si concentrano sulle comunicazioni tra applicazioni e server, analizzando i protocolli applicativi specifici (ad esempio SQL, SMTP)
- **Hybrid IDS**: combinano più approcci (NIDS, HIDS, PIDS, APIDS) per offrire una visione più completa e una maggiore efficacia nel rilevamento delle minacce^[27]

Le principali metodologie di rilevamento degli IDS sono il rilevamento basato su **firme** (Signature-based IDS), questi sistemi confrontano il traffico di rete o le attività di sistema con un database di firme di attacchi noti (pattern, sequenze di byte, hash).

^[28] Quando viene rilevata una corrispondenza, viene generato un allarme. Questo approccio è molto efficace contro minacce già conosciute, ma non rileva attacchi nuovi o varianti non ancora catalogate. ^[26] Rilevamento basato su anomalie (Anomaly-based IDS), questa metodologia crea un modello di comportamento normale (baseline) per la rete o il sistema e segnala tutte le deviazioni significative da questo modello come potenziali intrusioni. L'Anomaly-based IDS sfrutta spesso tecniche di intelligenza artificiale e machine learning per adattarsi nel tempo.

^[26]

I sistemi ibridi combinano le metodologie signature-based e Anomaly-based, sfruttando i punti di forza di entrambe per aumentare la copertura e ridurre i limiti specifici di ciascun approccio. Questi sistemi sono in grado di rilevare sia minacce note che nuove, migliorando la precisione e riducendo i falsi positivi. ^[26]

2.2.1 Suricata

Suricata è un motore open source di rilevamento delle minacce di rete sviluppato dalla Open Information Security Foundation (OISF).



Progettato come sistema di Intrusion Detection System (IDS), Intrusion Prevention System (IPS) e strumento di Network Security Monitoring (NSM), Suricata combina analisi del traffico in tempo reale, ispezione approfondita dei pacchetti (DPI) e un'architettura multi-threaded per garantire prestazioni elevate e scalabilità. La sua capacità di integrare metodologie di rilevamento basate su firme, anomalie e logiche personalizzate lo rende uno strumento versatile per la difesa proattiva delle reti moderne.^{[29][30]}

Sfrutta un'architettura multi-threaded per distribuire il carico di lavoro su più core CPU, superando i limiti di scalabilità dei sistemi single-threaded come Snort. Questo consente di analizzare traffico ad alta velocità (fino a 100 Gbps in configurazioni ottimizzate) senza sacrificare la profondità dell'ispezione.^[30]

Suricata supporta librerie come libpcap, AF_PACKET e PF_RING per la cattura efficiente dei pacchetti, analizza nativamente oltre 20 protocolli (HTTP, TLS, DNS, SSH) per identificare anomalie a livello applicativo e utilizza un motore di regole compatibile con Snort e un database aggiornabile (es. Emerging Threats) per il rilevamento di minacce note. Inoltre, permette l'implementazione di logiche personalizzate per il rilevamento di attacchi avanzati (es. Heartbleed) e genera log in formati strutturati (JSON, EVE) per l'integrazione con SIEM (Elasticsearch, Splunk) e piattaforme di analisi.^[31]

2.2.2 Snort

Snort è un sistema open source di Intrusion Detection/Prevention System (IDS/IPS) sviluppato da Martin Roesch e attualmente mantenuto da Cisco Systems. Snort combina analisi del traffico di rete in tempo reale, rilevamento basato su firme e ispezione approfondita dei protocolli per identificare attività malevole. La sua flessibilità, scalabilità e integrazione con strumenti di sicurezza avanzati lo rendono una soluzione chiave per la protezione di reti aziendali, infrastrutture critiche e ambienti cloud.^[32]

Snort opera attraverso un'architettura modulare che include il monitoraggio passivo del traffico senza generare alert (Sniffer Mode), registrazione dei pacchetti per l'analisi forense (Packet



Logger Mode) e l'analisi del traffico in tempo reale, generando alert o bloccando attacchi attivamente (IDS/IPS Mode). [32]

Supporta la decodifica di numerosi protocolli di rete, incluso TCP, UDP, ICMP, and HTTP, ed il preprocessore di Snort normalizza e pulisce il traffico rimuovendo il rumore prima che i dati vengano analizzati, inoltre tramite l'applicazione di regole personalizzate consente di identificare pattern di attacco (es.: exploit SQLi, port scanning).

2.2.3 Zeek

Zeek (precedentemente noto come Bro) è un framework open source per il monitoraggio della sicurezza di rete. A differenza dei tradizionali IDS basati su firme, Zeek adotta un approccio **orientato alla logica di rete**, trasformando il traffico grezzo in dati strutturati tramite analisi semantica dei protocolli. Questo consente non solo il rilevamento di intrusioni, ma anche la ricostruzione forense di attività sospette e la generazione di log contestualizzati per l'analisi post-evento. [33]

Zeek opera attraverso un'architettura a due livelli, ovvero un **Event Engine** che analizza i pacchetti a livello di trasporto e applicazione, ricostruendo flussi TCP/UDP e decodificando protocolli (HTTP, DNS, SSH, TLS), e genera eventi in tempo reale per attività rilevanti, ed un **Policy Script Interpreter**: Esegue script personalizzati in un linguaggio dedicato, permettendo di definire logiche di rilevamento complesse basate su condizioni, correlazioni o anomalie. [33]

Supporta librerie come **libpcap**, **PF_RING** e **AF_PACKET** per la cattura efficiente del traffico, è capace di decodificare oltre 20 protocolli applicativi, estraendo metadati (es. URI HTTP, query DNS, certificati TLS), genera log strutturati in formato JSON o TSV (es. conn.log per connessioni, http.log per traffico web) e offre mitigazioni attive degli attacchi (es. bloccare IP tramite integrazione con firewall). [33]

2.3 SIEM

I sistemi **Security Information and Event Management (SIEM)** rappresentano una tecnologia fondamentale per la gestione



proattiva della sicurezza informatica. Integrano funzionalità di **Security Information Management (SIM)** e **Security Event Management (SEM)**, fornendo una piattaforma centralizzata per l'aggregazione, l'analisi e la correlazione di dati di sicurezza provenienti da fonti eterogenee. Questi includono endpoint, server, applicazioni, firewall, sistemi di rilevamento delle intrusioni (IDS/IPS) e dispositivi di rete. L'obiettivo principale è offrire una visibilità completa del panorama di sicurezza, identificare minacce in tempo reale e supportare la risposta agli incidenti. ^[34]

I SIEM raccolgono log grezzi da tutte le sorgenti definite (es. syslog, API, agent), questi dati vengono convertiti in un formato strutturato (es. CEF, JSON) per facilitare l'analisi, dove i motori di analisi applicano regole predefinite, machine learning o modelli statistici per identificare pattern sospetti (es. tentativi di accesso falliti ripetuti da uno stesso IP), tramite la generazione di alert, eventi correlati attivano notifiche contestualizzate, prioritarizzate in base alla gravità, infine i log vengono archiviati per periodi estesi (fino a 7 anni) per garantire compliance normativa (GDPR, PCI-DSS) e analisi forensi. ^{[34] [35]}

I SIEM moderni hanno superato l'approccio basato su sole firme statiche, adottando tecnologie avanzate:

- **User and Entity Behavior Analytics (UEBA):** Rileva anomalie comportamentali (es. accessi insoliti a database da parte di utenti autorizzati) tramite modelli di machine learning.
- **Threat Intelligence Integration:** Correla eventi interni con feed esterni (es. indicatori di compromissione da MITRE ATT&CK) per identificare campagne avanzate.



- **Security Orchestration:** Automatizza workflow complessi (es. isolamento automatico di endpoint infetti). [34] [35]

2.3.1 Wazuh

Wazuh è una piattaforma di sicurezza open source pensata per fornire una gestione unificata di prevenzione, individuazione e risposta agli attacchi, la sua architettura è progettata per carichi su infrastrutture on-premises, virtualizzate, containerizzate e cloud. Una delle sue peculiarità è quella di poter integrare le funzionalità di Security Information and Event Management (SIEM) ed Extended Detection and Response (XDR) in un unico prodotto, offrendo un approccio completo alla sicurezza, questo lo rende un'interessante alternativa ad altre soluzioni proprietarie più costose.[36]

Il cuore della piattaforma è l'analisi dei log, il sistema acquisisce, aggrega ed analizza in tempo reale i log generati da una moltitudine di fonti all'interno dell'infrastruttura IT, per garantire interoperabilità e coerenza, Wazuh utilizza decodificatori e regole per normalizzare i dati acquisiti rendendoli compatibili e facilmente analizzabili. [37]

Approfondendo questo meccanismo, si scopre un'architettura a due stadi che trasforma il dato grezzo in intelligence attuabile. In primo luogo, i decoder analizzano e normalizzano i log, estraendo campi significativi come indirizzi IP, nomi utente o ID di evento.[40]

```
<!-- File: /var/ossec/etc/decoders/local_decoder.xml -->
```




```

<decoder name="custom_audit_decoder">
  <prematch>^audit: </prematch>
</decoder>

<decoder name="custom_audit_decoder_fields">
  <parent>custom_audit_decoder</parent>
  <regex>user='(\S+)' cmd='(.*?)'</regex>
  <order>user, cmd</order>
</decoder>

```

Esempio di decoder personalizzato per l'estrazione dell'informazione "user" e "cmd"

Successivamente, il motore di analisi confronta questi dati strutturati con un set di regole, definite in formato XML. Le regole personalizzate, cruciali per adattare il sistema a un ambiente specifico, vengono inserite nel file `local_rules.xml` per evitare che vengano sovrascritte durante gli aggiornamenti. Ogni regola è caratterizzata da un ID univoco e un livello di severità (level). La vera potenza risiede nella capacità di creare catene logiche tramite il tag `<if_sid>`, che permette a una regola di attivarsi solo se un'altra regola genitore è già scattata. Condizioni più complesse possono essere definite per rilevare attacchi basati sulla ripetitività di un evento, utilizzando attributi come `frequency` e `timeframe` per identificare, ad esempio, un numero sospetto di tentativi di login falliti in un breve lasso di tempo.^[41]

```

<!-- File: /var/ossec/etc/rules/local_rules.xml -->

<group name="custom,linux,commands,">

  <rule id="100100" level="15">
    <if_sid>530</if_sid>

```



```
<decoded_as>custom_audit_decoder</decoded_as>
<field name="cmd" type="pcre2">^rm -rf /$</field>
  <description>Comando critico 'rm -rf /' eseguito
    dall'utente: $(user).</description>
  <mitre>
    <id>T1485</id>
  </mitre>
</rule>

</group>
```

Esempio di Regola personalizzata che rileva l'esecuzione del comando "rm -rf /"

Le sue capacità di rilevamento delle intrusioni sono un altro pilastro fondamentale, che combina tecniche basate su firme e comportamento per rilevare attività sospette. Può rilevare processi mascherati, file nascosti e anomalie del traffico dirette fornendo ai team di sicurezza un'immagine completa delle minacce potenziali. A supporto di ciò la funzionalità di File Integrity Monitoring (FIM) tiene traccia in tempo reale delle modifiche a file e cartelle importanti per il sistema, utilizzando algoritmi di hashing per rilevare eventuali manomissioni e garantire l'integrità. [38]

Per affrontare la sfida delle vulnerabilità software, Wazuh integra un modulo di rilevamento che correla i dati dell'inventario software degli endpoint con database di vulnerabilità ed esposizioni comuni (CVE) costantemente aggiornati, consentendo di identificare software a rischio, [39] parallelamente, la funzione di Security Configuration Assessment (SCA) monitora le impostazioni di configurazione di sistemi e applicazioni per assicurare la conformità con le policy di sicurezza e le guide di hardening, come i benchmark definiti dal Center for Internet Security (CIS). [37]

In caso di incidente, fornisce strumenti per una risposta efficace e tempestiva, offre risposte attive predefinite che possono essere attivate per contrastare le minacce in corso, come il blocco di un indirizzo IP sospetto o l'esecuzione di comandi remoti per isolare un sistema compromesso. Queste capacità di automazione della risposta agli incidenti sono essenziali per mitigare rapidamente i danni di un attacco. La piattaforma estende la sua protezione anche agli ambienti cloud, monitorando l'infrastruttura a livello di API per i principali provider come Amazon Web Services (AWS), Microsoft



Azure e Google Cloud, e offre visibilità sulla sicurezza degli host e dei container Docker. [37]

In caso di incidente, Wazuh fornisce strumenti per una risposta efficace e tempestiva. Il sistema non si limita a generare allarmi, ma può eseguire **risposte attive** (active responses) per contrastare le minacce in corso. Questo meccanismo si basa sulla configurazione definita nel file `ossec.conf` del manager Wazuh, dove un blocco `<active-response>` associa l'attivazione di una regola con un livello di severità specifico all'esecuzione di un comando o di uno script. La piattaforma include script predefiniti per azioni comuni, come il blocco di un indirizzo IP sospetto tramite `firewall-drop`, ma la sua vera forza risiede nella capacità di invocare **script esterni personalizzati**. Un analista può, ad esempio, scrivere uno script in Bash, PowerShell o Python per isolare un endpoint dalla rete, terminare un processo malevolo o acquisire dati forensi, e configurare Wazuh per eseguirlo automaticamente quando un allarme critico viene generato. Lo script riceve automaticamente il contesto dell'allarme (come l'IP di origine o il nome dell'agente), rendendo la risposta automatizzata non solo rapida, ma anche contestuale e precisa. [42]

```
<!-- File: /var/ossec/etc/ossec.conf -->

<ossec_config>
  <command>
    <name>disable-user</name>
    <executable>disable-user.sh</executable>
    <expect>user</expect>
  </command>
  <active-response>
    <command>disable-user</command>
    <location>agent</location>
    <rules_id>100100</rules_id>
  </active-response>
</ossec_config>
```

Esempio di risposta attiva che esegue "disable-user.sh" quando viene attivata la regola "100100"

Essendo distribuito con licenza GPLv2, non comporta costi di licenza e offre alle organizzazioni la libertà di modificare e ridistribuire il software secondo le proprie necessità. Questo lo rende una soluzione estremamente conveniente, in particolare per le piccole e medie imprese o per le organizzazioni con budget di sicurezza limitati. [36]



2.3.2 IBM QRadar

Nel panorama dei SIEM, IBM QRadar si posiziona come una soluzione leader, progettata per fornire ai Security Operations Center (SOC) capacità avanzate di rilevamento, analisi e risposta alle minacce informatiche. Si distingue per il suo forte orientamento all'integrazione dell'intelligenza artificiale (AI) e dell'automazione con l'obiettivo di ridefinire l'efficacia operativa degli analisti di sicurezza. La sua architettura mira a offrire velocità, scalabilità e precisione, elementi fondamentali per contrastare la crescente sofisticazione degli avversari nel cyberspazio.^[43]

Al centro della proposta di valore di IBM QRadar si trova un'architettura profondamente integrata con l'**intelligenza artificiale (AI)** e il **machine learning (ML)**. La piattaforma sfrutta queste tecnologie per superare il semplice rilevamento basato su regole, offrendo un'analisi avanzata delle minacce, l'arricchimento contestuale degli allarmi, una prioritizzazione intelligente degli incidenti e una correlazione automatizzata degli eventi ^[43]. Questa enfasi sull'automazione non solo riduce il carico di lavoro manuale degli analisti, ma consente anche di generare avvisi più accurati e contestualizzati, facilitando una rapida identificazione e risposta. Inoltre, la piattaforma offre la flessibilità di costruire modelli di machine learning personalizzati per adattarsi a scenari di minaccia specifici ^[43].

Parallelamente all'analisi dei log e del comportamento utente, QRadar integra capacità di **Network Detection and Response (NDR)**. Questa funzionalità permette di analizzare l'attività di rete in tempo reale, fornendo un quadro più completo del panorama delle minacce. Combinando l'analisi dei log con il monitoraggio del traffico di rete, attraverso componenti come QRadar Network Insights, il sistema offre un'analisi approfondita dei metadati di rete e del contenuto applicativo, arricchendo ulteriormente il contesto investigativo. ^{[43][44]}

Per affrontare le sfide degli ambienti IT ibridi, QRadar introduce la **ricerca federata**, una capacità che consente di interrogare simultaneamente dati distribuiti su fonti disparate, sia on-premises che nel cloud, senza la necessità di una migrazione preventiva.



Questo approccio risolve il problema dei silos di dati, garantendo agli analisti una visibilità completa durante le indagini ^[43]. La gestione di queste complesse attività è centralizzata nel **Centro di Rilevamento e Risposta**, un'interfaccia unificata che semplifica l'adozione e la gestione dei casi d'uso di rilevamento, includendo un editor di regole intuitivo per migliorare l'efficienza operativa ^[45].

In risposta all'evoluzione del panorama delle minacce, IBM ha esteso le capacità di QRadar per allinearsi al paradigma dell'**Extended Detection and Response (XDR)**, QRadar XDR unifica le funzionalità di EDR (Endpoint Detection and Response), NDR (Network Detection and Response) e SIEM in un unico flusso di lavoro. Questa integrazione olistica, che include componenti come IBM QRadar EDR (precedentemente ReaQta) e IBM QRadar SOAR, mirando a fornire una gestione delle minacce end-to-end, combinando il rilevamento accurato con l'orchestrazione, l'automazione e la risposta agli incidenti. L'obiettivo è quindi collegare le informazioni provenienti da diversi livelli di sicurezza (endpoint, rete, cloud, e-mail) e automatizzare le attività di risposta per una risoluzione più rapida ed efficace ^[46].

2.3.3 Splunk

Splunk Enterprise Security (ES), comunemente noto come Splunk SIEM, rappresenta una delle soluzioni più affermate e potenti nel mercato della gestione delle informazioni e degli eventi di sicurezza. Il suo obiettivo primario è fornire alle organizzazioni una visibilità completa sulla propria infrastruttura IT, consentendo di monitorare, rilevare e analizzare potenziali minacce alla sicurezza in modo centralizzato ^[47]. Come indicato nell'analisi comparativa, Splunk si distingue per la sua eccezionale **flessibilità nell'analisi dei dati** e per un **vasto ecosistema di integrazioni**, che lo rendono una piattaforma di riferimento per le organizzazioni che necessitano di capacità di indagine profonde e personalizzabili.

L'architettura di Splunk Enterprise Security è progettata per fungere da hub analitico per i Security Operations Center (SOC). Offre una piattaforma centralizzata che integra dati, intelligence e contesto per l'analisi approfondita degli incidenti attraverso il suo **Workbench di Investigazione** ^[47]. Questo approccio è supportato da una serie di funzionalità avanzate. Una delle più significative è il



Risk-Based Alerting (RBA), un meccanismo che si discosta dall'allertamento basato su soglie statiche per prioritizzare le minacce attribuendo punteggi di rischio dinamici a utenti e sistemi. Tale metodo è finalizzato a ridurre il rumore di fondo e i falsi positivi, migliorando drasticamente la produttività del SOC ^{[47][48]}.

La piattaforma impiega l'**analisi comportamentale** basata su machine learning per rilevare anomalie e minacce interne o avanzate che sfuggirebbero a un'analisi basata su regole tradizionali ^[47]. Per fornire un contesto investigativo più ricco, Splunk ES integra nativamente il framework **MITRE ATT&CK**, consentendo agli analisti di mappare rapidamente le attività malevole alle tattiche e tecniche note degli avversari ^[49]. La visibilità è ulteriormente potenziata dalla capacità di mappare la **Topologia delle Minacce**, che collega visivamente gli oggetti di rischio alle minacce per definire l'ambito di un incidente ^[47].

La gestione dei dati è un punto di forza fondamentale di Splunk. La piattaforma è rinomata per la sua capacità di raccogliere, indicizzare e analizzare in modo efficiente enormi volumi di log da fonti eterogenee, supportando ambienti on-premises, cloud e ibridi ^[50]. Questa **gestione flessibile dei dati**, che include sia formati strutturati che non strutturati, unita a capacità di **ricerca veloce e visualizzazione avanzata**, costituisce il cuore della sua potenza analitica, permettendo analisi forensi dettagliate per comprendere la causa e l'estensione delle violazioni ^{[48][50]}.



3. CAPITOLO III

Ideazione della soluzione

L'obiettivo di questo capitolo è la spiegazione del flusso di lavoro seguito per lo sviluppo e la sperimentazione del lavoro svolto, descrivendone nel dettaglio le fasi che lo compongono.

Le fasi principali coinvolte nello sviluppo sono state il deployment delle piattaforme usate, T-pot e Wazuh, le loro configurazione che hanno permesso la comunicazione tra i due sistemi tramite il passaggio dei log della piattaforma honeypot (T-pot) e il SIEM (Wazuh). La fase successiva è stata lo sviluppo del modello di Machine Learning, che ha coinvolto l'utilizzo di tecniche di apprendimento supervisionato, come già affrontato nel Capitolo III. In seguito dopo lo sviluppo del modello di Machine Learning, quest'ultimo è stato coinvolto nella creazione di un collegamento con Suricata (IDS), che è una componente integrata all'interno di T-pot, dove sono stati eseguiti dei passaggi di trasformazione dei flussi di rete per renderli operabili dal modello. Dopo la fase di collegamento del modello e Suricata è avvenuto l'inoltro delle previsioni generate dal modello a Wazuh, che tramite un monitoraggio continuo potranno essere processate nell'ultima fase del flusso di lavoro dove verrà effettuato il deploy delle risposte agli attacchi rilevati dal modello, da parte di Wazuh tramite le sue capacità di "Active Response".

3.1 Paradigma della Soluzione

Il panorama contemporaneo della cybersecurity è definito da un'escalation di minacce la cui complessità e dinamicità superano sovente le capacità dei paradigmi di difesa tradizionali. Come



emerso dall'analisi dello stato dell'arte sui sistemi SIEM (Security Information and Event Management), la gestione proattiva della sicurezza informatica postula una visibilità olistica dell'infrastruttura e meccanismi di identificazione delle minacce in tempo reale. Ciononostante, una criticità intrinseca delle soluzioni SIEM convenzionali risiede nell'elevato volume di eventi generati, con un'incidenza di falsi positivi che, in assenza di un tuning meticoloso e dispendioso in termini di risorse umane, può inficiare l'efficacia del rilevamento.

La presente trattazione si prefigge di superare tali limitazioni attraverso la formulazione di un'architettura ibrida e intelligente. L'obiettivo è la progettazione di un sistema integrato che trascenda la mera aggregazione di log per implementare un ciclo di sicurezza cibernetica completo e automatizzato. Tale architettura si fonda sui seguenti principi metodologici:

- **Detection basata su Deception Technology:** Impiego di un sistema honeypot (T-pot) quale fonte di dati ad alta fedeltà. In linea con le traiettorie evolutive dei SIEM moderni, l'adozione di tecnologie di inganno consente di isolare attività malevole, garantendo che le interazioni registrate posseggano, per definizione, un'elevata probabilità di essere indicative di una minaccia.
- **Analisi basata su Intelligenza Artificiale:** Integrazione del modello di Machine Learning, il cui sviluppo è stato trattato nel Capitolo 3, quale motore analitico avanzato. Tale componente supera l'approccio deterministico basato su firme, applicando modelli stocastici per una classificazione accurata della natura della minaccia, mitigando così una delle principali sfide operative dei SIEM.
- **Orchestrazione e Risposta Automatica (SIEM/SOAR):** Utilizzo di una piattaforma SIEM (Wazuh) caratterizzata da elevata flessibilità, non solo come collettore di log, ma come orchestratore centrale. In accordo con le moderne funzionalità di Security Orchestration, Automation, and Response (SOAR), il sistema è progettato per processare gli



alert qualificati dal modello ML e attivare contromisure automatiche.

3.2 Componenti Tecnologiche

La selezione dei componenti tecnologici è stata guidata da criteri di flessibilità, interoperabilità e capacità analitica, al fine di costruire un sistema sinergico.

3.2.1 Honeypot: T-pot

La piattaforma T-pot agisce quale "sensore proattivo" dell'architettura. La sua funzione precipua non è difensiva, bensì quella di esporre una superficie d'attacco eterogenea e controllata, finalizzata ad attrarre, registrare e caratterizzare le Tattiche, Tecniche e Procedure (TTP) degli avversari. La sua integrazione nativa con l'IDS Suricata è di cruciale importanza, in quanto fornisce i dati di flusso di rete grezzi (raw network data) che costituiscono l'input per il nostro modulo analitico.

3.2.2 Modello di Machine Learning

Il modello di classificazione rappresenta il "nucleo cognitivo" del sistema. Esso è stato concepito per affrontare le limitazioni dei SIEM convenzionali, quali l'elevato tasso di falsi positivi e la dipendenza dall'expertise umano per il tuning delle regole di correlazione. Il suo compito è elaborare i dati forniti da Suricata, applicare la pipeline di feature engineering definita e formulare un giudizio inferenziale di alto livello, contestualizzato e quantificato (es. "Classificazione: Attacco DDoS; Score di confidenza: 0.98"). Questo processo trasforma un dato a basso contenuto semantico (log di rete) in un evento di sicurezza arricchito (intelligence-driven security event).

3.2.3 SIEM: Wazuh

Wazuh è stato selezionato come "orchestratore centrale" in virtù della sua architettura open-source e, in particolare, della sua **comprovata flessibilità e personalizzazione**. Come evidenziato dall'analisi comparativa, Wazuh si configura come una "piattaforma unificata XDR e SIEM", la cui architettura modulare basata su



decoder e regole estensibili costituisce il prerequisito fondamentale per l'integrazione di fonti di dati non standard, quali le previsioni generate dal nostro modello. La sua funzionalità nativa di **"Incident Response" (Active Response)** fornisce il meccanismo effettivo per l'automazione delle contromisure, completando così il ciclo "detection-to-response".

3.3 Flusso Logico dei Dati

Il design della soluzione si articola in un flusso operativo sequenziale e logico, che modella la trasformazione di un'attività ostile in un'azione di difesa automatizzata.

1. **Fase di Cattura:** Un attore malevolo interagisce con i servizi emulati dalla piattaforma T-pot. Il traffico di rete afferente a tale interazione viene intercettato dall'IDS Suricata.
2. **Fase di Analisi e Normalizzazione:** Il flusso di rete viene processato in tempo reale dal "Modulo di Trasformazione delle Feature", che astrae da esso il vettore di feature richiesto dal modello ML. Il modello effettua un'inferenza, classificando l'evento e generando un output strutturato in formato CSV, che rappresenta la normalizzazione e l'arricchimento semantico dell'evento.
3. **Fase di Correlazione e Alerting:** L'output CSV viene trasmesso a Wazuh via script SHELL. Un **decoder personalizzato** effettua il parsing del messaggio, estraendo i campi semantici rilevanti (es. classificazione della minaccia, indirizzo IP sorgente). Una **regola di correlazione specifica** valuta i dati estratti e, al verificarsi delle condizioni predefinite, genera un alert di alta severità, rendendolo disponibile sulla dashboard di gestione.
4. **Fase di Risposta e Mitigazione:** La generazione dell'alert critico innesca l'esecuzione automatica di una **risposta attiva (Active Response)**. Uno script di mitigazione viene invocato, ricevendo l'indirizzo IP dell'attore malevolo come argomento, e procede a inserire una regola di blocco nella configurazione del firewall di sistema.



4. CAPITOLO IV

Machine Learning

Il Machine Learning (ML) o apprendimento automatico, è una sottocategoria delle Intelligenze Artificiali (AI), la disciplina che si occupa dello studio degli “agenti intelligenti”. Un agente intelligente può essere definito come un'entità in grado di percepire il proprio ambiente e di intraprendere azioni che massimizzino le sue probabilità di raggiungere con successo i propri obiettivi. All'interno del vasto dominio dell'IA, il Machine Learning si distingue come l'area focalizzata sullo sviluppo di agenti capaci di migliorare le proprie prestazioni attraverso l'esperienza. Più formalmente, si può adottare la seguente definizione:

“Si dice che un programma apprende dall'esperienza E , con riferimento a una classe di compiti T e a una misura di prestazione P , se le sue prestazioni nei compiti T , misurate da P , migliorano con l'esperienza E .” [Mitchell T., 1997]

Le tecniche di Machine Learning possono essere suddivise in diverse categorie, le principali delle quali sono l'apprendimento supervisionato (supervised learning) e non supervisionato (unsupervised learning). L'apprendimento supervisionato include tutti quei metodi che presuppongono la disponibilità di dati etichettati (labelled data), ovvero dati a cui è stato associato un valore atteso, tipicamente da un supervisore umano, che funge da “target” o obiettivo. Al contrario, gli approcci che non richiedono dati etichettati e non hanno un target predefinito sono detti non supervisionati; ne sono un esempio gli algoritmi di clustering e di riduzione della dimensionalità.

Inoltre, i modelli supervisionati possono essere ulteriormente distinti in due sottogruppi: classificazione e regressione. Mentre i modelli di regressione hanno come output un valore continuo,



quelli di classificazione producono in output un valore discreto, ovvero una classe di appartenenza. Data la natura dei dati utilizzati nell'esperimento condotto in questo lavoro e del problema affrontato, è stato impiegato esclusivamente un algoritmo di classificazione **Random Forest**. Un modello non supervisionato in questo caso sarebbe stato più adatto in assenza di etichette o in presenza di un obiettivo esplorativo per individuare pattern o anomalie sconosciute nei dati.

Infine, è importante sottolineare che il processo di apprendimento di ogni modello di Machine Learning segue alcune fasi comuni, che includono una serie di buone pratiche volte a prevenire problematiche comuni come l'overfitting e a garantire la generalizzabilità del modello. Queste fasi, che vanno dalla preparazione dei dati alla valutazione del modello, verranno analizzate nel dettaglio nel prosieguo del capitolo.

4.1 Preparazione dei dati

La performance e l'affidabilità di un modello di machine learning dipendono in modo critico dalla qualità e dalla preparazione dei dati su cui viene addestrato. Un dataset grezzo, per quanto ricco di informazioni, è raramente utilizzabile in modo diretto. È pertanto necessario un rigoroso processo di preparazione dei dati (Data Preparation) che trasforma i dati grezzi in un formato strutturato, pulito e ottimizzato per l'algoritmo di apprendimento. La preparazione dei dati è una fase critica in qualsiasi pipeline di Machine Learning, soprattutto per un dataset complesso come il CIC-IDS2017, data la sua dimensione, l'eterogeneità delle feature e lo sbilanciamento delle classi.

4.1.1 Dataset

Il dataset CIC-IDS2017, sviluppato dal Canadian Institute for Cybersecurity, si distingue per il suo realismo e la sua completezza. È stato generato catturando il traffico di rete di un'infrastruttura simulata per un periodo di cinque giorni, durante i quali sono stati eseguiti sia traffico benigno sia una vasta gamma di attacchi informatici moderni. Il risultato è un insieme di dati che comprende oltre 2.8 milioni di flussi di rete, ciascuno descritto da 78 feature



numeriche estratte tramite lo strumento CICFlowMeter. Queste feature catturano informazioni temporali e statistiche sui flussi, come la durata, il numero di pacchetti, la dimensione dei pacchetti e gli intervalli tra di essi.

Per garantire una copertura ampia e rappresentativa delle diverse tipologie di traffico e di attacchi, sono stati utilizzati molteplici file CSV provenienti dal dataset CICIDS2017, dove ogni file rappresenta uno scenario specifico di traffico di rete (attacchi DDoS, DoS, PortScan, traffico benigno, Botnet, Bruteforce, Web Attacks). L'unione di questi file, effettuata tramite caricamento e concatenazione in un unico Dataframe, consente di costruire un dataset complessivo che include sia il traffico ordinario sia molteplici scenari di attacco, aumentando la robustezza e la generalizzabilità del modello. Questa scelta permette di addestrare e testare l'algoritmo in contesti realistici e variabili, riflettendo la complessità di un ambiente di rete reale.

Il dataset è etichettato con una feature "Label" che identifica ogni flusso come BENIGN o come una specifica categoria di attacco, questa granularità lo rende ideale per problemi di classificazione binaria (attacco vs. benigno) e multiclasse (identificazione del tipo di attacco).

Una volta caricati i dati, è stata condotta un'attenta fase di pulizia e normalizzazione delle etichette (Label), dove i nomi delle colonne sono stati uniformati rimuovendo gli eventuali spazi superflui. Il problema principale, tuttavia, risiedeva nella frammentazione delle etichette di attacco, ad esempio, gli attacchi di tipo "Denial of Service" erano suddivisi in più categorie specifiche come DoS Hulk e DoS GoldenEye. Per risolvere il problema della frammentazione è stata applicata una mappatura per accorpare etichette simili in categorie di attacco più generali e significative, quali DoS, DDoS, PortScan, Brute Force, Web Attack e Bot, è stato scelto inoltre di rimuovere dal dataset le classi estremamente rare come "Heartbleed" e "Infiltration". È stata scelta questa soluzione per semplificare il numero delle classi target, evitando così che il modello venisse influenzato da classi troppo rare o poco significative, che a causa dei bassi numeri di campioni avrebbero influenzato negativamente l'apprendimento del modello portando a risultati poco soddisfacenti e all'introduzione di rumore.



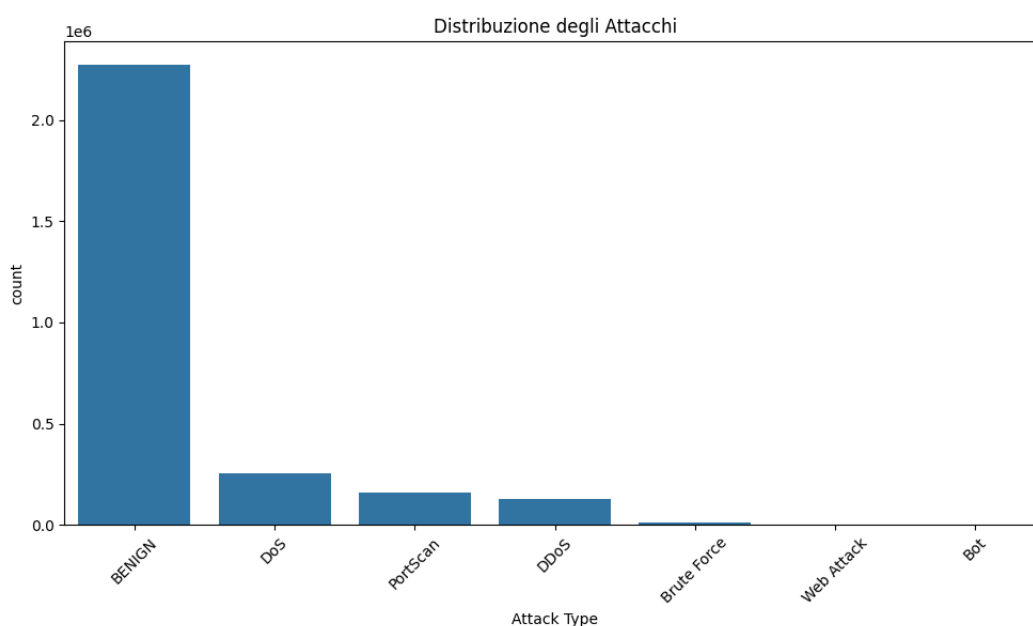


Figura 4.1 – Distribuzione degli attacchi post pulizie e normalizzazione

4.1.2 Feature Engineering

La performance di un modello di Machine Learning è intrinsecamente legata alla qualità e alla preparazione dei dati di addestramento. È stato fondamentale trasformare i dati grezzi in un formato numerico, coerente e ottimizzato per l'algoritmo di apprendimento. Sono state applicate operazioni di imputazione dei valori anomali o mancanti (NaN, Infinity), spesso derivanti da divisioni per zero o errori di acquisizione del traffico, che sono stati gestiti tramite **imputazione con la media** della rispettiva colonna, questo approccio permette di preservare la distribuzione statistica delle feature. Successivamente, tutte le feature numeriche sono state normalizzate nell'intervallo [0, 1] tramite "MinMaxScaler". Sebbene gli algoritmi basati su alberi come Random Forest non siano strettamente dipendenti dalla scalatura, questa pratica previene problemi con feature a varianza molto diversa e uniforma il loro contributo in altre fasi dell'analisi, come quella di spiegabilità.

A causa dell'elevato numero di feature presenti nel dataset, per ridurre il rischio di overfitting e migliorare l'efficienza computazionale, è stata implementata una strategia di selezione delle feature. È stata utilizzata la tecnica di filtro univariata del **Chi-quadro (χ^2)**, che misura la dipendenza statistica tra ciascuna feature



e la variabile target. Sono state selezionate le **20 feature** con il punteggio χ^2 più elevato, ritenute le più informative per la discriminazione tra le classi di attacco. Il test del Chi-quadro è particolarmente indicato in questo contesto, poiché valuta la dipendenza tra feature numeriche non negative e una variabile target categorica, che è esattamente il nostro caso d'uso. Questo approccio basato su test univariati permette di scartare le feature meno rilevanti in modo rapido ed efficace. La matrice di correlazione tra le feature selezionate mostra una bassa multicollinearità, indicando che le feature scelte sono in gran parte indipendenti tra loro e portatrici di informazioni distinte.

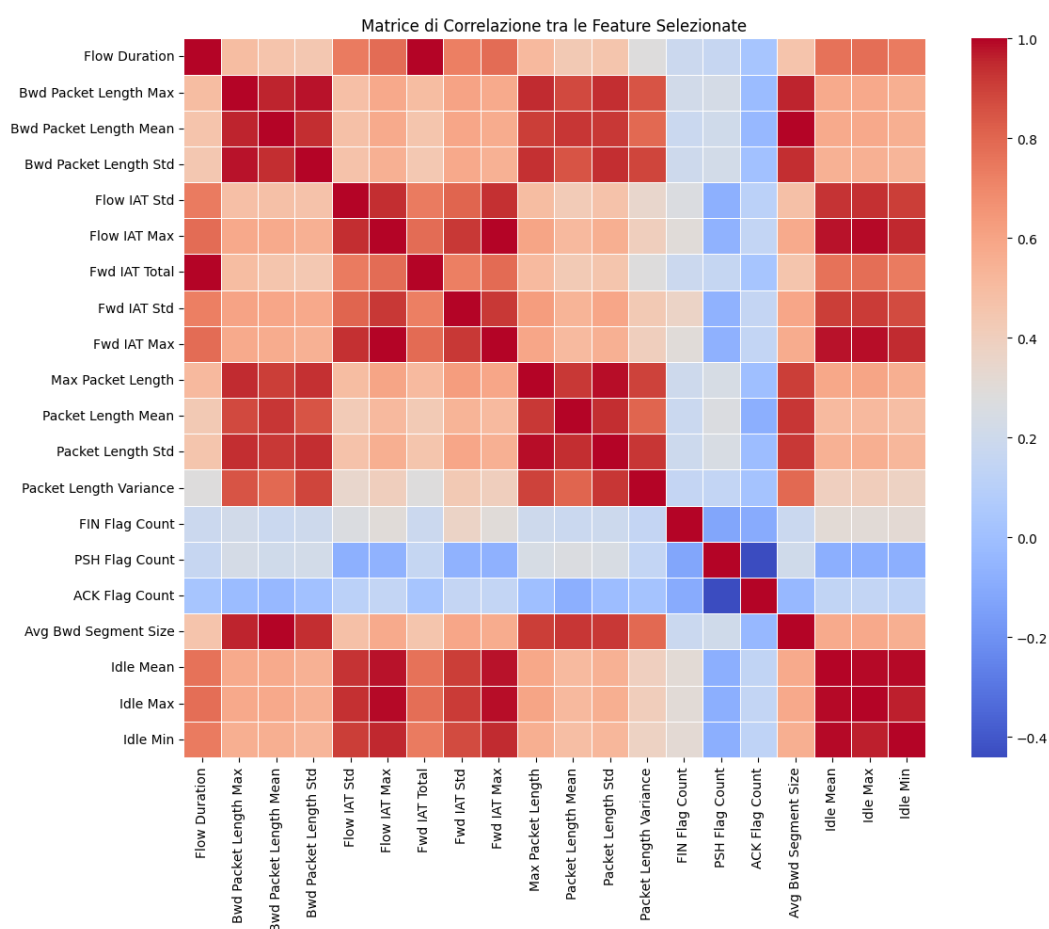


Figura 4.2 – Heatmap di correlazione tra le 20 feature selezionate.



4.2 Addestramento del Modello

Una volta preparato il dataset, si entra nella fase di costruzione e addestramento del modello predittivo, questa fase non si limita alla semplice applicazione di un algoritmo ai dati, ma implica decisioni strategiche cruciali che ne determinano l'efficacia finale. La scelta più significativa in questo contesto è stata quella di adottare un approccio comparativo, addestrando e valutando due modelli distinti: il primo sul dataset nella sua forma originale e intrinsecamente sbilanciata, e il secondo su una versione del dataset opportunamente bilanciata tramite tecniche di ricampionamento.

Questa doppia strategia non è una mera ridondanza, ma è finalizzata a comprendere e quantificare l'impatto dello sbilanciamento delle classi sulle performance del classificatore. La decisione di perseguire entrambi i percorsi permette di ottenere una valutazione olistica, analizzando il classico trade-off tra la validità ecologica del modello e la sua efficacia nella rilevazione delle classi minoritarie.

4.2.1 Divisione dei Dati e Strategia di Valutazione

Per garantire una valutazione robusta e imparziale dei modelli, è stata adottata una strategia di Cross-Validation Stratificata con 5 fold. Questa tecnica di divisione dei dati è particolarmente indicata per dataset sbilanciati, poiché assicura che ogni "fold" di addestramento e validazione mantenga la stessa proporzione di classi del dataset completo. Questo approccio previene stime di performance eccessivamente ottimistiche o pessimistiche e fornisce una misura più affidabile della capacità di generalizzazione del modello. La medesima strategia di cross-validation è stata impiegata sia per la valutazione finale dei modelli sia durante la fase di ottimizzazione degli iperparametri.



4.2.2 Addestramento su Dati Sbilanciati

Il primo modello è stato addestrato direttamente sul dataset post-preprocessing, senza alcuna modifica alla distribuzione delle classi. Questo approccio è stato definito come la nostra baseline ecologica. Il termine "ecologico" si riferisce al fatto che il modello viene esposto ai dati così come si presenterebbero in un ambiente operativo reale, dove il traffico benigno è preponderante rispetto a quello malevolo.

L'addestramento su dati sbilanciati serve a stabilire un punto di riferimento fondamentale. L'ipotesi di partenza è che un algoritmo standard, se non corretto, svilupperà un forte bias verso la classe maggioritaria (traffico BENIGN). Di conseguenza, ci si attende che questo modello esibisca un'accuracy complessiva molto elevata, poiché predirebbe correttamente la maggior parte delle istanze semplicemente classificandole come benigne. Tuttavia, questa metrica sarebbe ingannevole, infatti l'obiettivo di questo primo addestramento è verificare e misurare la debolezza del modello nell'identificare correttamente le classi di attacco (le classi minoritarie), dove ci si aspetta un basso valore di recall per queste classi, e quindi valutare il tasso di falsi positivi in uno scenario realistico. Questo modello, quindi, pur essendo potenzialmente debole nel rilevamento, rappresenta uno scenario operativo in cui si privilegia la minimizzazione degli errori sul traffico legittimo. Per questo addestramento sono stato utilizzati degli iperparametri predefiniti e ragionevoli, i quali sono un numero di stimatori, cioè il numero di alberi presenti nella "foresta" pari a 50 e una profondità per albero di 20.

4.2.3 Addestramento su Dati Bilanciati

Il secondo modello è stato addestrato su una versione del dataset bilanciata artificialmente. Come evidenziato dall'analisi esplorativa e dalla Figura 4.1, il traffico benigno costituisce la stragrande maggioranza delle istanze, mentre le classi di attacco sono significativamente sottorappresentate, quindi per mitigare il bias, è stata implementata una strategia di ricampionamento ibrida, combinando tecniche di "undersampling" e "oversampling":



- **Random Undersampling:** Le classi maggioritarie (BENIGN, DoS, PortScan, DDoS) sono state sotto-campionate, riducendo casualmente il loro numero di istanze a 100.000 ciascuna. Questo passo riduce il bias verso queste classi e alleggerisce notevolmente il carico computazionale della fase successiva.
- **Random Oversampling:** Successivamente, sul dataset risultante dal sotto-campionamento, è stato applicato un sovra-campionamento. Questa tecnica aumenta la numerosità delle classi minoritarie duplicando casualmente le loro istanze, fino a che tutte le classi raggiungono lo stesso numero di campioni della classe più numerosa (in questo caso, 100.000).

L'obiettivo di questa strategia è costringere l'algoritmo di apprendimento a dare la stessa importanza a ogni classe, inclusi gli attacchi più rari. Il modello risultante dovrebbe, in teoria, essere molto più efficace nel raggiungimento dell'obiettivo primario dell'esperimento, la rilevazione delle minacce.

A differenza del modello baseline, per il classificatore addestrato sui dati bilanciati è stata eseguita un'approfondita fase di **Ricerca degli Iperparametri** per identificare la configurazione ottimale. È stata utilizzata la tecnica **Grid Search con Cross-Validation**, un metodo sistematico che testa esaustivamente tutte le possibili combinazioni di iperparametri definite in una griglia.

La griglia di ricerca è stata configurata per esplorare i seguenti parametri:

- **Numero di stimatori (`n_estimators`)**, cioè il numero di alberi nella foresta (valori testati: [50, 100, 150]).
- **Profondità massima (`max_depth`)** di ciascun albero (valori testati: [20, 30, None], dove "None" indica una profondità illimitata).
- **Numero minimo di campioni (`min_samples_leaf`)** richiesti per essere una foglia (valori testati: [1, 2, 4]).



Per ogni combinazione di iperparametri, il modello è stato addestrato e valutato utilizzando la Cross-Validation stratificata a 5 fold, con l'F1-score pesato come metrica di riferimento per la performance. Al termine di questo processo, è stata identificata la seguente combinazione come ottimale:

- max_depth: None
- min_samples_leaf: 1
- n_estimators: 50

4.2.4 Scelta e Addestramento del Classificatore

L'algoritmo scelto per questo task di classificazione è il Random Forest Classifier. Questa scelta è motivata da diverse sue caratteristiche intrinseche, particolarmente adatte al contesto dei dati di rete:

- **Robustezza all'Overfitting:** Essendo un metodo di ensemble learning basato su alberi decisionali, il Random Forest riduce la varianza e il rischio di overfitting rispetto a un singolo albero, aggregando le predizioni di molteplici alberi addestrati su sottoinsiemi casuali dei dati e delle feature.
- **Gestione di Dati Complessi:** È in grado di modellare relazioni non lineari complesse tra le feature, una caratteristica comune nei dati di traffico di rete.
- **Importanza delle Feature:** Fornisce nativamente una metrica di importanza delle feature (basata sulla riduzione media dell'impurità di Gini), che è stata utilizzata per validare e analizzare i risultati della fase di selezione.

4.3 Test del Modello e Metriche

La fase di valutazione è essenziale per quantificare oggettivamente le performance dei modelli sviluppati e per confrontare l'efficacia dell'approccio bilanciato rispetto alla baseline ecologica. La metodologia di valutazione è stata basata sulla **Cross-Validation Stratificata a 5 fold**, garantendo una stima robusta e imparziale delle capacità di generalizzazione di ciascun classificatore.



Per ottenere una visione completa delle performance, sono state utilizzate diverse metriche standard per problemi di classificazione: **accuracy**, **precision**, **recall** e **F1-score**. In contesti di sicurezza informatica, dove le classi sono spesso sbilanciate, l'accuracy da sola può essere ingannevole. Pertanto, l'**F1-score pesato (f1_weighted)** è stato scelto come metrica principale, poiché calcola la media armonica di precision e recall, tenendo conto del supporto (numero di istanze) di ciascuna classe.

I risultati della Cross-Validation per il modello addestrato sui dati originali (**sbilanciati**) sono i seguenti:

- **accuracy**: 0.9859 ± 0.0001
- **precision_weighted**: 0.9864 ± 0.0001
- **recall_weighted**: 0.9859 ± 0.0001
- **f1_weighted**: 0.9857 ± 0.0001

Come ipotizzato, il modello ottiene punteggi estremamente elevati, con un F1-score medio di **0.9857**. Questo risultato, sebbene apparentemente eccellente, è fortemente influenzato dal bias verso la classe maggioritaria BENIGN. Il modello ottiene un'alta accuracy prevedendo correttamente la maggior parte del traffico come benigno, ma la sua capacità di rilevare attacchi rari rimane limitata.

I risultati della Cross-Validation per il modello ottimizzato con Grid Search e addestrato sui dati **bilanciati** sono:

- **accuracy**: 0.9776 ± 0.0003
- **precision_weighted**: 0.9780 ± 0.0002
- **recall_weighted**: 0.9776 ± 0.0003
- **f1_weighted**: 0.9775 ± 0.0003



Il modello bilanciato raggiunge un F1-score di **0.9775**. Sebbene questo valore sia marginalmente inferiore a quello della baseline, riflette una performance significativamente più robusta ed equilibrata. Il bilanciamento del dataset ha costretto il modello a migliorare la sua capacità di identificare le classi minoritarie, rendendolo molto più efficace per l'obiettivo primario di un sistema di rilevamento delle minacce. Il confronto diretto degli F1-score, visualizzato in **Figura 4.3**, evidenzia come il bilanciamento dei dati produca un modello con performance quasi equivalenti, ma con una maggiore affidabilità nel rilevamento degli attacchi.

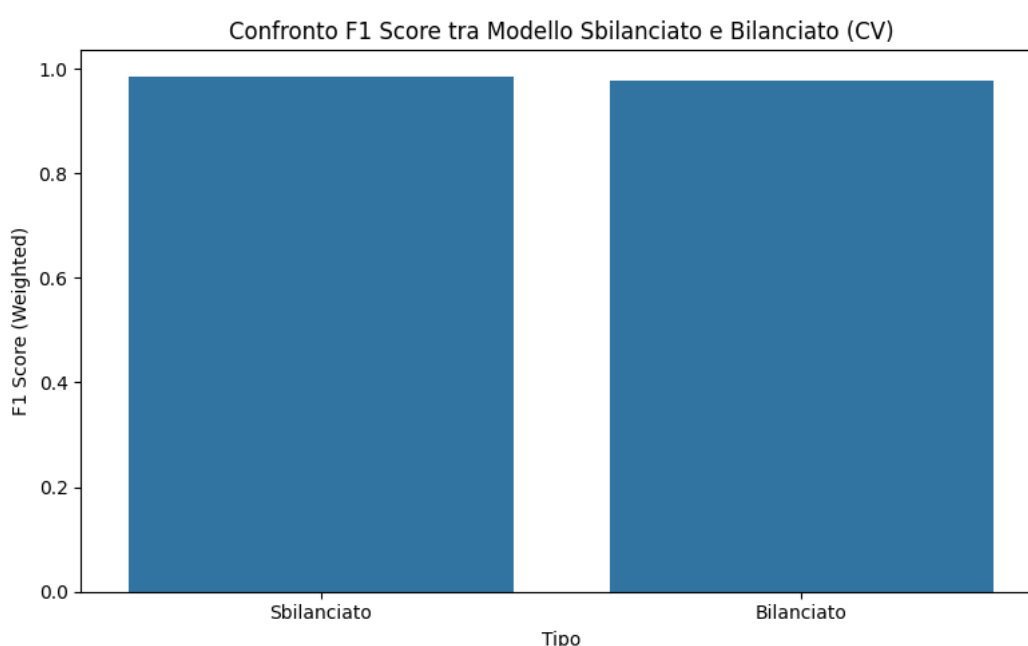


Figura 4.3 – Confronto dei punteggi F1 dei Modelli

Per diagnosticare potenziali problemi di overfitting o underfitting, sono state generate le curve di apprendimento per entrambi i modelli. Queste curve illustrano l'andamento dell'F1-score in funzione della dimensione del training set.



Nel **Modello Sbilanciato** la curva mostra che sia lo score di training che quello di Cross-Validation convergono rapidamente verso un valore molto alto, con un divario minimo tra le due. Questo indica che il modello generalizza bene sulla distribuzione dei dati sbilanciati e non soffre di overfitting.

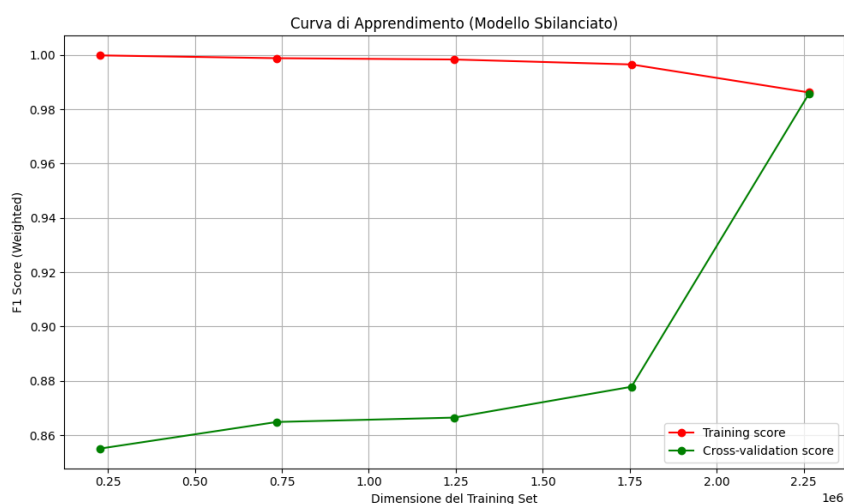


Figura 4.4 – Curva di apprendimento del Modello Sbilanciato

Nel **Modello Bilanciato** le curve di training e di Cross-Validation convergono, dimostrando che il modello è stabile e generalizza efficacemente. Il leggero divario tra le due curve è tipico di un modello ben calibrato, che non ha "imparato a memoria" i dati di training.

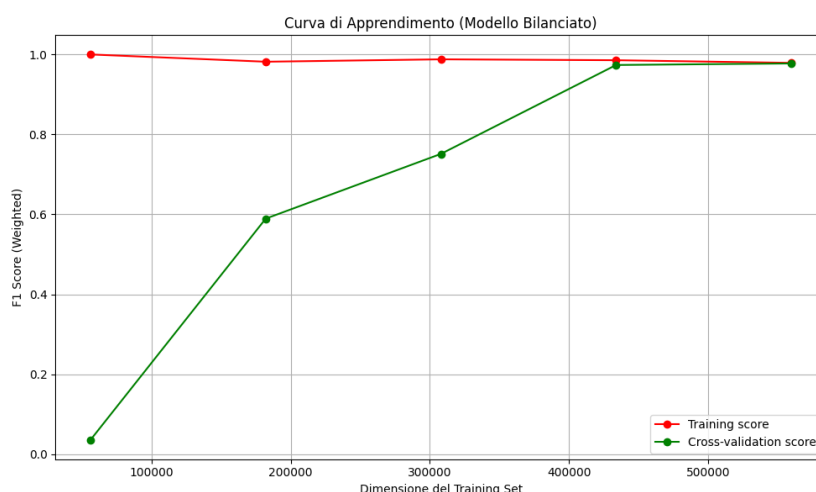


Figura 4.5 – Curva di apprendimento del Modello Bilanciato



4.4 Spiegabilità del Modello (eXplainable AI)

Per evitare che i modelli agiscano come "scatole nere" e per aumentare la fiducia nelle loro predizioni, è stata condotta un'analisi di spiegabilità utilizzando la metodologia **SHAP (SHapley Additive exPlanations)**. SHAP è un approccio basato sulla teoria dei giochi che quantifica il contributo di ciascuna feature alla predizione di una singola istanza, offrendo una visione dettagliata e interpretabile del comportamento del modello.

4.4.1 Analisi dell'Importanza delle Feature

L'importanza globale delle feature è stata misurata calcolando il valore SHAP medio assoluto per ciascuna di esse. I grafici a barre mostrano le feature più influenti per entrambi i modelli.

Nel **Modello Sbilanciato (Figura 4.6)** le feature più determinanti sono risultate essere "Bwd Packet Length Std" (deviazione standard della lunghezza dei pacchetti all'indietro), "Avg Bwd Segment Size" (dimensione media dei segmenti all'indietro) e "Packet Length Mean" (media della lunghezza dei pacchetti). Queste caratteristiche sono prevalentemente legate alla dimensione e alla variabilità dei pacchetti.

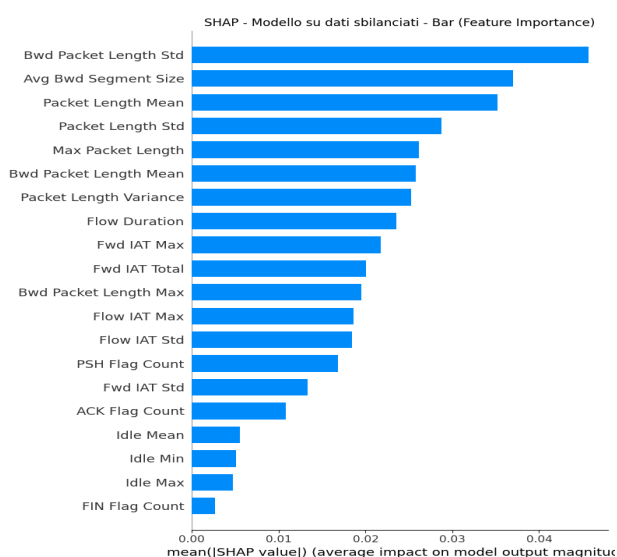


Figura 4.6 – Grafico dell'importanza delle feature del Modello Sbilanciato



Mente nel **Modello Bilanciato (Figura 4.7)**, dopo il bilanciamento del dataset, la classifica delle feature più importanti subisce una variazione significativa. Sebbene “Bwd Packet Length Std” mantenga la sua posizione dominante, emergono come cruciali anche “Flow Duration” (durata del flusso) e “Fwd IAT Std” (deviazione standard del tempo tra arrivi dei pacchetti in avanti).

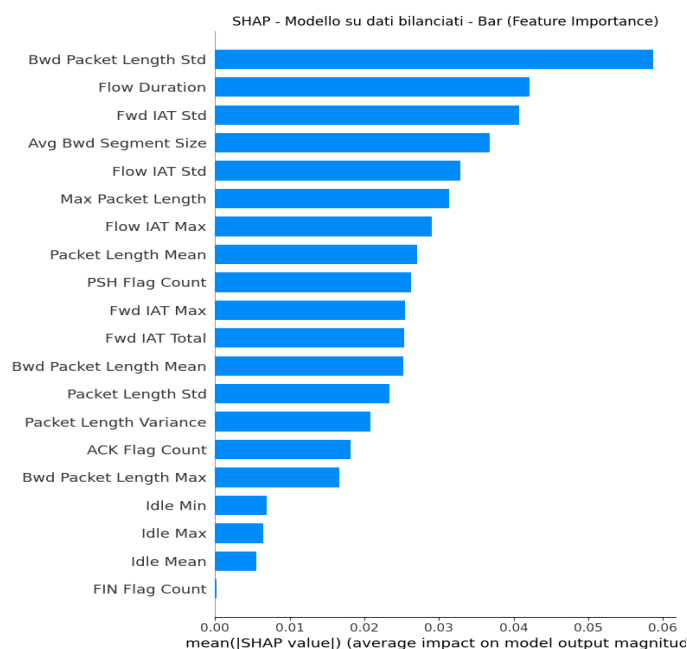


Figura 4.7 – Grafico a barre dell'importanza delle feature del Modello Bilanciato

4.4.2 Interpretazione delle Differenze tra i Modelli

Il confronto tra i due grafici offre intuizioni preziose sull'impatto del bilanciamento dei dati sul processo di apprendimento del modello:

1. **Feature Robusta e Consistente:** La feature **Bwd Packet Length Std** si conferma come l'indicatore più potente in entrambi i modelli. Questo suggerisce che la variabilità nella dimensione dei pacchetti inviati dal server al client è un marcatore estremamente affidabile per distinguere il traffico anomalo da quello benigno, indipendentemente dalla distribuzione delle classi.



2. **Impatto del Bilanciamento sulle Feature Temporali:** La differenza più notevole risiede nell'aumento di importanza delle **feature basate sul tempo** nel modello bilanciato. Flow Duration e Fwd IAT Std (jitter dei pacchetti) diventano cruciali. Questo fenomeno può essere spiegato dal fatto che il bilanciamento del dataset costringe il modello a non concentrarsi più solo sulla distinzione tra la classe maggioritaria (BENIGN) e il resto, ma a imparare i pattern specifici che differenziano le varie tipologie di attacco (DoS, DDoS, PortScan, etc.). Molti di questi attacchi sono caratterizzati da pattern temporali anomali (es. flussi molto lunghi o molto corti, o variazioni anomale nel tempo tra i pacchetti), rendendo queste feature temporali estremamente discriminatorie per il modello bilanciato.
3. **Adattamento della Logica del Modello:** Il modello sbilanciato, dominato dalla classe BENIGN, dà priorità a feature come Avg Bwd Segment Size, che sono efficaci nel separare grandi volumi di traffico normale da quello palesemente anomalo in termini di dimensione dei pacchetti. Al contrario, il modello bilanciato impara a "prestare attenzione" a segnali più sottili, come le tempistiche dei flussi, che sono fondamentali per identificare le classi di attacco minoritarie che sono state sovra-campionate.

4.4.3 Analisi del Comportamento del Modello

I grafici SHAP summary (noti anche come *beeswarm plot*) offrono una visione ancora più granulare, mostrando non solo l'importanza di una feature, ma anche l'**impatto dei suoi valori** sulla predizione. In questi grafici, ogni punto rappresenta una singola predizione; la sua posizione sull'asse X indica il valore SHAP e il suo colore rappresenta il valore della feature (alto in rosso, basso in blu).



È fondamentale notare che i valori SHAP sono stati calcolati rispetto alla **classe 0 (BENIGN)**. Pertanto:

- Un **valore SHAP positivo** (a destra dello zero) indica che la feature spinge la predizione del modello verso la classe **BENIGN**.
- Un **valore SHAP negativo** (a sinistra dello zero) spinge la predizione lontano dalla classe BENIGN, ovvero verso una **classe di attacco**.

Analizzando i grafici di entrambi i modelli (**Figura 4.8 e 4.9**), si osserva un comportamento logico e interpretabile

- **Modello Sbilanciato (Figura 4.8):**

Per la feature Avg Bwd Segment Size, si nota che **valori bassi** (punti blu) hanno un forte impatto **positivo**, aumentando significativamente la probabilità che il flusso sia **BENIGN**. Al contrario, valori elevati (punti rossi) hanno un impatto fortemente negativo, indicando la presenza di un attacco. Analogamente, per PSH Flag Count, un valore basso (punti blu, indicante l'assenza o la scarsità di flag PSH) è un forte indicatore di traffico **BENIGN**.

- **Modello Bilanciato (Figura 4.9):**

- La feature Bwd Packet Length Std mostra un pattern chiaro: **valori bassi** (punti blu) hanno un impatto **positivo** (più probabile che sia BENIGN), mentre **valori alti** (punti rossi), indicativi di una maggiore variabilità, hanno un impatto **negativo**, suggerendo la presenza di un attacco. Flow Duration si comporta in modo simile, con flussi di breve durata (punti blu) associati a traffico BENIGN (valore SHAP positivo), mentre flussi di lunga durata (punti rossi), tipici di attacchi come DoS, che spingono la predizione verso una classificazione di attacco (valore SHAP negativo).



Questa analisi SHAP non solo convalida la robustezza delle feature selezionate, ma conferma anche che i modelli hanno appreso pattern logicamente correlati alle caratteristiche note degli attacchi di rete. Questo livello di trasparenza è cruciale per costruire fiducia nelle decisioni del modello e per fornire indicazioni utili agli analisti di sicurezza.

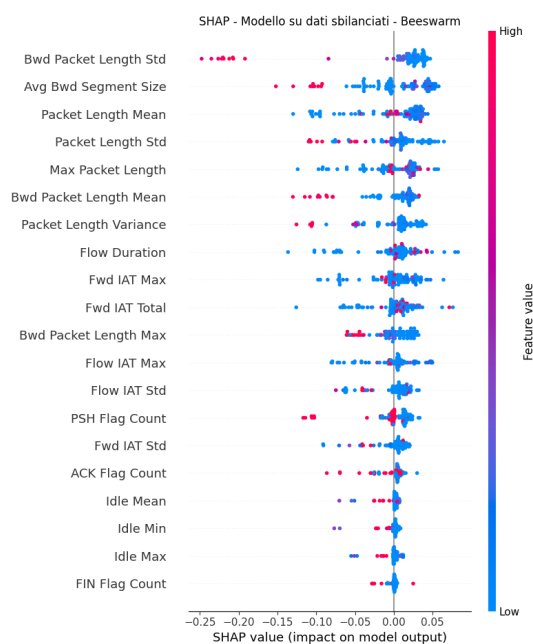


Figura 4.8 – Grafico Beeswarm del Modello Sbilanciato

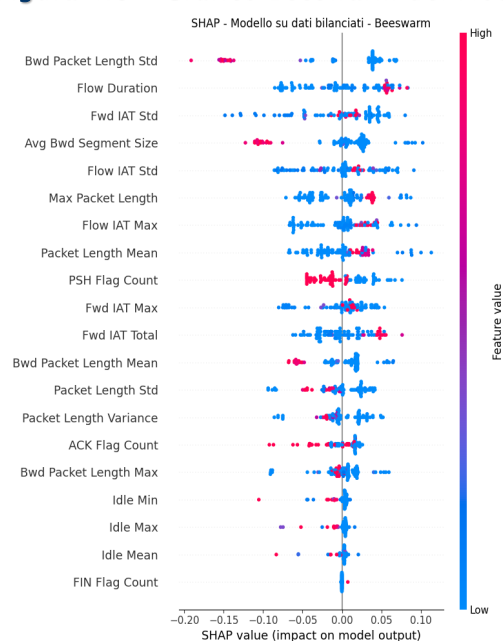


Figura 4.9 – Grafico Beeswarm del Modello Bilanciato



5. CAPITOLO V

Integrazione delle Piattaforme

Il Capitolo 3 ha delineato l'architettura concettuale e il paradigma operativo della soluzione proposta, mentre il seguente capitolo si focalizzerà sulla sua produzione pratica, descrivendo nel dettaglio le procedure di configurazione, le interfacce d'integrazione e gli script sviluppati per realizzare il flusso di rilevamento e risposta end-to-end. L'obiettivo, quindi, è dimostrare la fattibilità tecnica dell'architettura e fornire un modello producibile per l'integrazione di sistemi di "deception" con analisi basata su Machine Learning e orchestrazione SIEM.

5.1 Configurazione del Flusso di Dati T-pot – Wazuh

A differenza di un approccio basato sull'inoltro generico dei log (es. via Syslog), si è optato per una strategia di integrazione più granulare e robusta, che prevede il deployment di un agente Wazuh direttamente sull'host che ospita la piattaforma T-pot. Questa scelta metodologica offre vantaggi significativi in termini di controllo, flessibilità e affidabilità nella raccolta dei log.

5.1.1 Deployment

L'infrastruttura è stata configurata su macchine virtuali distinte per il manager di Wazuh e la piattaforma T-pot.

Tramite la dashboard di Wazuh, è stato creato un gruppo di agenti dedicato denominato "HoneypotServer", questo approccio centralizzato ha permesso di applicare configurazioni specifiche, garantendo uniformità e scalabilità. Successivamente è stato installato sulla macchina dove risiedeva T-pot un agente Wazuh e gli è stato assegnato il gruppo "HoneypotServer".



5.1.2 Configurazione della Raccolta dei Log

La configurazione per la raccolta dei dati è stata definita centralmente nel file “agent.conf” del gruppo “HoneypotServer”, dove si è istruito l'agent a monitorare e acquisire il contenuto dei file di log specifici, fondamentali per l'analisi.

Il file agent.conf è stato popolato con le seguenti direttive:

```
<agent_config>
  <!-- Acquisizione log di Cowrie in formato JSON -->
  <localfile>
    <log_format>json</log_format>

    <location>/home/mongelli/tpotce/data/cowrie/log/cowrie.json
  </location>
  </localfile>
  <!-- Acquisizione log di Suricata (EVE) in formato JSON -->
  <localfile>
    <log_format>json</log_format>
    <location>/home/mongelli/tpotce/data/suricata/log/eve.json
  </location>
  </localfile>
</agent_config>
```

Questa configurazione abilita l'agente a leggere in tempo reale gli eventi generati dagli honeypot Cowrie e dall'IDS Suricata, specificando che tali log sono già strutturati in formato JSON, il che facilita il successivo parsing da parte del motore di Wazuh.

5.1.3 Configurazione dei Log (Suricata)

Una volta garantito il flusso di dati dall'agente al manager, è stato necessario estendere la logica di analisi di Wazuh per interpretare correttamente, qualificare e contestualizzare gli eventi specifici provenienti dagli honeypot. Questo è stato realizzato tramite la creazione di regole personalizzate, definite nel file “/var/ossec/etc/rules/local_rules.xml”.

Gli alert generati da Suricata vengono inizialmente processati dalle regole predefinite di Wazuh, e per migliorare la visibilità e la contestualizzazione, è stato creato un gruppo di regole personalizzate “Honeypot Alerts”.



Queste regole utilizzano il tag “<if_sid>” per agire come figlie della regola base di Suricata aggiungendo due livelli di logica:

- **Filtrano** gli eventi solo se provenienti da un hostname specifico, isolando così gli alert generati dal nostro honeypot.
- Assegnano un **livello di severità** crescente (da 11 a 15) basandosi sul campo “alert.severity” presente nel log originale di Suricata. Questo permette una prioritizzazione immediata degli alert.

Inoltre, nella descrizione dell'alert, vengono utilizzati campi dinamici come “\$(alert.signature)” e “\$(src_ip)” per creare un messaggio immediatamente leggibile e ricco di contesto per l'analista.

5.1.4 Configurazione dei Log (Cowrie)

Per l'honeypot Cowrie, sono state create regole specifiche per monitorare due tipi di attività critiche, i tentativi di autenticazione e i comandi eseguiti dopo un'eventuale compromissione.

- **Tentativi di Login:** La regola 100075 si attiva quando rileva un evento con “eventid” pari a “cowrie.login.failed”, questo permette di identificare tentativi di brute force o di credential stuffing contro l'honeypot.
- **Esecuzione di Comandi:** La regola 100076, di severità più elevata (livello 13), è cruciale per il threat hunting, in quanto cattura i comandi che un attaccante esegue dopo aver ottenuto l'accesso. Questo fornisce un'intelligence preziosa sulle TTP post-exploitation dell'avversario.

5.2 Implementazione del Modello di Machine Learning

Una volta stabilito il flusso di dati di base tra T-pot e Wazuh, il passo successivo e più innovativo dell'architettura consiste nell'inserire il modulo di analisi basato su Machine Learning. Questo componente non si occupa dell'addestramento, già trattato nel Capitolo 4, ma dell'applicazione pratica del modello pre-addestrato per la classificazione del traffico di rete in tempo reale. La sua implementazione è stata realizzata attraverso uno script



Python, che funge da "ponte intelligente" tra i dati grezzi di Suricata e il motore di alerting di Wazuh.

5.2.1 Monitoraggio e Orchestrazione del Flusso di Lavoro

Per garantire un'analisi tempestiva del traffico di rete, è stato sviluppato uno script Bash che agisce come un demone di monitoraggio sulla macchina di T-pot. Il suo ruolo è quello di orchestrare l'intero processo di analisi, dalla rilevazione dei dati grezzi all'invocazione dello script di inferenza. La sua logica operativa è la seguente:

1. **Monitoraggio del Flusso di Rete:** Lo script utilizza l'utilità `inotifywait` per monitorare in modo efficiente e a basso overhead la directory dei log di Suricata `/home/mongelli/tpotce/data/suricata/log`. Nello specifico, è configurato per reagire all'evento di creazione di nuovi file con estensione `"pcap"`. I file con estensione `"pcap"` contengono la cattura completa del traffico di rete associato a un determinato alert di Suricata.
2. **Invocazione del Tool di Feature Extraction (CICFlowMeter):** Alla rilevazione di un nuovo file `pcap`, lo script di monitoraggio invoca il tool **CICFlowMeter**. Questo strumento, sviluppato dal Canadian Institute for Cybersecurity, è fondamentale in quanto implementa l'algoritmo standard per l'estrazione delle 78 feature di flusso dal traffico di rete grezzo. Lo script passa il file `pcap` come input a **CICFlowMeter**, il quale produce in output un file `.csv` contenente i flussi di rete e le relative caratteristiche.
3. **Invocazione dello Script di Inferenza:** Una volta che **CICFlowMeter** ha generato il file CSV, lo script di monitoraggio procede ad attivare l'ambiente virtuale Python e a eseguire lo script di inferenza `ml_detector.py`, passandogli il percorso del file CSV appena creato come argomento da linea di comando. Questo approccio garantisce che le dipendenze dello script siano isolate dal resto del sistema.
4. **Gestione dello Stato e Trasferimento dei Log:** Lo script implementa meccanismi di robustezza, come il "locking" dei



file per evitare elaborazioni multiple dello stesso file pcap e la registrazione dei file già processati. Al termine dell'analisi, lo script si occupa di trasferire i log degli attacchi rilevati a un server remoto tramite scp, per una centralizzazione e un'analisi successiva.

5.2.2 Generazione degli Alert

Lo script Python `ml_detector.py` costituisce il motore decisionale del sistema. Riceve come input il percorso del file CSV generato da `CICFlowMeter` ed esegue una pipeline di preelaborazione e predizione:

1. **Caricamento e Pre-elaborazione dei Dati:** Lo script carica il file CSV del flusso di rete in un `DataFrame`, ed esegue operazioni di pulizia e normalizzazione delle colonne per garantire la coerenza con il formato dei dati su cui il modello è stato addestrato.
2. **Applicazione della Pipeline di Predizione:** Viene effettuato il caricamento degli Artefatti del Modello precedentemente salvati durante la fase di addestramento del Capitolo 4. Vengono caricati il **modello Random Forest**, l'oggetto **LabelEncoder** che è essenziale per la decodifica delle predizioni, lo **StandardScaler** per la normalizzazione dei dati, l'**Imputer** per la gestione dei valori mancanti e le **feature selezionate** nella fase di addestramento. In seguito, i dati caricati vengono sottoposti alla stessa sequenza di trasformazioni applicata in fase di addestramento: imputazione dei valori mancanti, scaling e selezione delle feature pertinenti. Questo garantisce che i dati presentati al modello per l'inferenza abbiano la stessa distribuzione e struttura dei dati di training.



3. **Esecuzione dell'Inferenza e Generazione dei Log:** Il metodo “model.predict()” viene invocato sui dati trasformati per ottenere le etichette di predizione. Il risultato viene decodificato tramite il LabelEncoder per ottenere le etichette testuali e lo script filtra i risultati, isolando solo i flussi classificati come non 'BENIGN'. Infine, gli attacchi rilevati vengono de-duplicati per evitare alert multipli per lo stesso tipo di attacco tra la stessa coppia IP/porta e salvati in un **file CSV di output**. Questo file costituisce il **log strutturato degli attacchi**, che verrà poi trasferito alla macchina dove risiede Wazuh per l'analisi. Ogni riga del CSV contiene informazioni essenziali come l'IP sorgente, l'IP e la porta di destinazione, e l'etichetta dell'attacco predetto.

5.3 Implementazione della Risposta Attiva

Il completamento del ciclo di sicurezza, dal rilevamento alla mitigazione, è stato realizzato attraverso un'architettura di risposta attiva che integra gli output del modulo di Machine Learning con il motore di orchestrazione di Wazuh. Questo processo è articolato in diverse fasi logiche, implementate tramite script personalizzati e configurazioni specifiche del SIEM.

5.3.1 Ingestione e Normalizzazione degli Alert su Wazuh

Una volta che lo script di monitoraggio su T-pot ha trasferito i file CSV contenenti i log degli attacchi rilevati sulla macchina del manager Wazuh (nella directory /root/attack_logs), entra in funzione un secondo demone di monitoraggio, watcher.py.

Questo script Python è progettato per monitorare in tempo reale la directory di arrivo dei log utilizzando una logica di “watch”, che rileva la comparsa di nuovi log degli attacchi. Al rilevamento di un nuovo log degli attacchi, lo script lo processa riga per riga, ed esegue le seguenti operazioni:

1. **Conversione in formato JSON:** I dati tabulari del CSV vengono trasformati in un oggetto JSON strutturato, questo passaggio è cruciale per la normalizzazione dei dati e per facilitare il parsing da parte dei decoder di Wazuh.



2. **Arricchimento Semantico:** Ad ogni evento JSON viene aggiunto un timestamp preciso e altri metadati, se necessario, per aumentare il contesto.
3. **Scrittura su Log Centralizzato:** L'evento JSON viene accodato a un file di log centralizzato, questo file agisce come "bus" di comunicazione tra la pipeline di rilevamento e il motore di analisi di Wazuh.

Al termine dell'elaborazione, il file CSV originale viene spostato in una directory di archivio per prevenire rielaborazioni e per mantenere uno storico dei dati.

5.3.2 Integrazione con il Motore di Analisi di Wazuh

Il sistema Wazuh è stato configurato per trattare gli output del modulo ML come una fonte di dati primaria per il rilevamento di minacce.

Il file di configurazione del manager di Wazuh "ossec.conf" è stato esteso con una direttiva "<localfile>" per il monitoraggio continuo del file di log centralizzato. Tramite il motore di analisi di Wazuh riceve gli eventi salvati nel log in formato JSON e l'inoltra all'agente locale. Il motore applica il set di regole personalizzate, dove una regola genitore identifica gli eventi appartenenti alla pipeline ML, mentre regole figlie, più specifiche, effettuano il matching sul valore del campo "predicted_label". Infine, avviene l'attivazione di una di queste regole che culmina nella generazione di un alert di alta severità, che viene indicizzato e reso disponibile per i componenti successivi del flusso di lavoro.



5.3.3 Automazione della Risposta

La generazione di un alert qualificato innesca il framework di Risposta Attiva (Active Response) di Wazuh, che orchestra l'esecuzione di contromisure di contenimento.

All'interno della configurazione `ossec.conf`, gli ID delle regole associate ai rilevamenti ML sono stati mappati al comando di risposta attiva **“block-ip”**. È stata inoltre definita una direttiva **“<timeout>”**, che stabilisce la durata temporale del blocco che in questo caso corrisponde ad una durata di 3600 secondi. Successivamente il sistema invoca lo script `“block_ip.py”`, fornendogli in input un oggetto JSON contenente il contesto completo dell'alert, incluso l'indirizzo IP sorgente dell'attaccante. Lo script effettua il parsing dell'input, estrae l'indirizzo IP e, tramite un'invocazione al sottosistema netfilter del kernel Linux, inserisce una regola DROP nella catena INPUT della tabella filter di iptables. Tale operazione interrompe istantaneamente ogni flusso di traffico proveniente dalla sorgente malevola. Il **“timeout”** configurato agisce come un meccanismo di controllo temporale. Allo scadere del periodo definito, Wazuh invoca nuovamente lo stesso script di risposta, ma con un argomento **“delete”**. Lo script interpreta tale comando ed esegue l'operazione inversa, rimuovendo la regola di blocco precedentemente inserita. Questo paradigma di "blocco temporizzato" costituisce una contromisura resiliente, in grado di mitigare l'impatto di eventuali falsi positivi senza richiedere un intervento manuale per il ripristino della connettività.



6. CAPITOLO VI

Conclusioni

La presente dissertazione ha affrontato la sfida del rilevamento proattivo delle minacce informatiche, proponendo un'architettura ibrida che supera i limiti dei paradigmi di sicurezza convenzionali. Partendo da un'analisi critica dello stato dell'arte, che ha evidenziato le criticità dei sistemi di rilevamento basati su firme e le sfide operative dei SIEM tradizionali. L'obiettivo primario è stato la progettazione, l'implementazione e la validazione di un sistema integrato, capace di automatizzare l'intero ciclo di sicurezza, dal rilevamento alla risposta. Il percorso metodologico ha previsto la definizione di un'architettura sinergica basata su tecnologie di deception (T-pot), analisi avanzata tramite Machine Learning e orchestrazione SIEM (Wazuh). Una parte fondamentale del lavoro si è concentrata sullo sviluppo e la validazione di un modello di classificazione Random Forest, la cui efficacia è stata rigorosamente testata e la cui interpretabilità è stata indagata tramite metodologie di Explainable AI. La fase implementativa ha poi tradotto il blueprint teorico in una soluzione operativa, dettagliando gli script e le configurazioni necessarie per realizzare un flusso di lavoro end-to-end. I risultati sperimentali hanno confermato la validità dell'approccio: il modello ha dimostrato un'elevata accuratezza predittiva (F1-score di 0.9775) e l'architettura ha risposto con successo a un attacco simulato, attivando una contromisura di blocco automatica e temporizzata.

Il principale contributo di questo lavoro risiede nella proposizione di un paradigma architetturale ibrido e modulare, che dimostra come l'integrazione di componenti open-source specializzati possa dar vita a un sistema di sicurezza più efficace e intelligente. Dal punto di vista pratico, è stato fornito un blueprint tecnico riproducibile per l'operazionalizzazione di un motore di analisi ML



all'interno di un ecosistema SIEM, offrendo un caso di studio concreto per l'estensione di piattaforme esistenti. Inoltre, l'applicazione di tecniche di Explainable AI ha fornito intuizioni interpretabili sul comportamento del modello, accrescendone l'affidabilità e fornendo un valore aggiunto per gli analisti.

È tuttavia necessario riconoscere i limiti dello studio. La validazione è stata condotta in un ambiente di laboratorio controllato, e le performance del sistema potrebbero variare in contesti produttivi su larga scala. Inoltre, il modello di classificazione, addestrato su un dataset statico, è suscettibile al fenomeno del concept drift e richiederebbe strategie di riaddestramento continuo. Infine, la risposta attiva implementata, sebbene efficace, rappresenta una contromisura basilare, che potrebbe risultare insufficiente contro avversari sofisticati.



RIFERIMENTI

- [1] NETSCOUT, Reports DDoS Attacks Targeting Critical Infrastructure Play a Dominant Role in Geopolitical Conflicts, 2025 .
- [2] NETSCOUT, «DDoS Threat Intelligence Report,» 2024. [Online]. Available: <https://www.netscout.com/threatreport/>.
- [3] C. Conrad, «Botnets and Familiar Foes Drive DDoS Attack Activity,» 29 Aprile 2025. [Online]. Available: <https://www.netscout.com/blog/asert/botnets-and-familiar-foes-drive-ddos-attack-activity>.
- [4] J. Vijayan, «SQL Injection Attacks Represent Two-Third of All Web App Attacks,» 13 Giugno 2019. [Online]. Available: <https://www.darkreading.com/cyberattacks-data-breaches/sql-injection-attacks-represent-two-third-of-all-web-app-attacks>.
- [5] D. H. Kass, «Cross-Site Scripting Nearly 40% of All Online Cyber Attacks in 2019,» 7 Gennaio 2020. [Online]. Available: <https://www.msspalert.com/news/study-cross-site-scripting-attacks>.
- [6] Vectra, «Negazione del servizio (DoS),» 2025. [Online]. Available: <https://it.vectra.ai/attack-techniques/denial-of-service-dos>.
- [7] ACS, «Attacco DDoS: cos'è e come proteggersi,» 7 Luglio 2024. [Online]. Available: <https://www.acs.it/it/blog/sicurezza-informatica/attacco-ddos/>.
- [8] Akamai, «Che cos'è un attacco DDoS,» 2025. [Online]. Available: <https://www.akamai.com/it/glossary/what-is-ddos>.
- [9] CloudFlare, «Attacco di amplificazione DNS,» 2025. [Online]. Available: <https://www.cloudflare.com/it-it/learning/ddos/dns-amplification-ddos-attack/>.



- [1 Vectra, «Scansione della porta,» 2025. [Online]. Available:
0] <https://it.vectra.ai/attack-techniques/port-scan>.
- [1 KirstenS, «Cross Site Scripting (XSS),» OWASP, 22 Novembre
1] 2022. [Online]. Available: <https://owasp.org/www-community/attacks/xss/>.
- [1 A. Pratt, «Breaking Down the OWASP Top 10: Injection,» 21
2] Novembre 2024. [Online]. Available: <https://www.hackerone.com/blog/breaking-down-owasp-top-10-injection>.
- [1 OWASP, «Brute Force Attack,» 19 Aprile 2024. [Online].
3] Available: https://owasp.org/www-community/attacks/Brute_force_attack.
- [1 A. Subhan, Y. N. Kunang e I. Z. Yadi, «Analyzing the Attack
4] Pattern of Brute Force Attack on SSH Port,» 01 Dicembre 2023. [Online]. Available: <https://ieeexplore.ieee.org/document/10441929>.
- [1 J. M. jules, H. Cheng e G. R. Regedzai, «A Survey on Botnet
5] Attacks,» 5 Marzo 2021. [Online]. Available: https://asrjetsjournal.org/index.php/American_Scientific_Journal/article/view/6686/2352.
- [1 ClickGUARD, «The Most Recent Botnet Attacks: Trends and
6] Insights,» 6 Gennaio 2025. [Online]. Available: <https://www.clickguard.com/blog/recent-botnet-attacks/>.
- [1 Kaspersky, «Cos'è un honeypot?,» 24 Febbraio 2025. [Online].
7] Available: <https://www.kaspersky.it/resource-center/threats/what-is-a-honeypot>.
- [1 Telekom Security, «T-Pot – The All In One Multi Honeypot
8] Platform,» 14 Giugno 2025. [Online]. Available: <https://github.com/telekom-security/tpotce>.
- [1 A. Ka, «fingerprint all the things!,» 23 Marzo 2022. [Online].
9] Available: <https://github.com/0x4D31/fatt>.
- [2 S. Q., «Fingerprint passivo di un sistema con p0f,» 10 Settembre
0] 2013. [Online]. Available:



<https://www.html.it/articoli/fingerprint-passivo-di-un-sistema-con-p0f/>.

[2 Smicallef, «SpiderFoot,» 5 Novembre 2023. [Online]. Available:
1] <https://github.com/smicallef/spiderfoot>.

[2 D. D. Rogatis, «SpiderFoot: raccogliere informazioni su un
2] sistema facilmente,» 24 Settembre 2013. [Online]. Available:
<https://www.html.it/articoli/spiderfoot-raccogliere-informazioni-su-un-sistema-facilmente/>.

[2 Red Hot Cyber, «Programmi hacker: CyberChef, il coltellino
3] svizzero da pentest.,» 11 Aprile 2021. [Online]. Available:
<https://www.redhotcyber.com/post/programmi-hacker-cyberchef-coltellino-svizzero-da-penetration-tester/>.

[2 Thinkst, «OpenCanary,» 16 Maggio 2025. [Online]. Available:
4] <https://github.com/thinkst/opencanary>.

[2 Pwnlandia, «Modern Honey Network,» 13 Dicembre 2023.
5] [Online]. Available: <https://github.com/pwnlandia/mhn>.

[2 IBM, «Che cos'è un IDS?,» 19 Aprile 2023. [Online]. Available:
6] <https://www.ibm.com/it-it/topics/intrusion-detection-system>.

[2 PaloAlto Networks, «What is an Intrusion Detection System?,»
7] [Online]. Available:
<https://www.paloaltonetworks.co.uk/cyberpedia/what-is-an-intrusion-detection-system-ids>.

[2 Fortinet, «Che cos'è un sistema di rilevamento delle intrusioni
8] (IDS)?,» 2025. [Online]. Available:
<https://www.fortinet.com/it/resources/cyberglossary/intrusion-detection-system>.

[2 D. Robinette, «What are the benefits of Suricata?,» 23 Ottobre
9] 2023. [Online]. Available: www.stamus-networks.com/blog/what-are-the-benefits-of-suricata.

[3 M. Viglione, «Suricata: What is it and how can we use it,» 4
0] Marzo 2022. [Online]. Available:



<https://www.infosecinstitute.com/resources/network-security-101/suricata-what-is-it-and-how-can-we-use-it/>.

- [3 G. RS, «Guide to Suricata: Network Security, IDS, IPS, and NSM,»
1] 8 Agosto 2024. [Online]. Available:
<https://www.devzery.com/post/guide-to-suricata-network-security-ids-ips-and-nsm>.
- [3 J. Przypek, «Snort: A Comprehensive Guide to Intrusion
2] Detection,» 19 Gennaio 2025. [Online]. Available:
<https://www.linkedin.com/pulse/snort-comprehensive-guide-intrusion-detection-joshua-przypek-xgz1e/>.
- [3 University of Texas at San Antonio, «ZEEK INTRUSION
3] DETECTION SERIES,» 13 Marzo 2020. [Online]. Available:
https://research.cec.sc.edu/files/cyberinfra/files/Zeek_Lab_Series.pdf.
- [3 Tallinn University of Technology, « Analysis of SIEM Evasion and
4] Detection Methods,» 2016. [Online]. Available:
<https://mendillo.info/seguridad/tesis/Morteza.pdf>.
- [3 D. R. Miller, SIEM Efficiency in Enterprise Networks, Journal of
5] Cybersecurity, 2023.
- [3 Wazuh, «Wazuh Quickstart,» 2025. [Online]. Available:
6] <https://documentation.wazuh.com/current/quickstart.html>.
- [3 Wazuh, «Wazuh Data Analysis,» 2025. [Online]. Available:
7] <https://documentation.wazuh.com/current/user-manual/ruleset/index.html>.
- [3 Wazuh, «Wazuh File integrity monitoring,» 2025. [Online].
8] Available: <https://documentation.wazuh.com/current/user-manual/capabilities/file-integrity/index.html>.
- [3 Wazuh , «Wazuh Vulnerability Detection,» 2025. [Online].
9] Available: <https://documentation.wazuh.com/current/user-manual/capabilities/vulnerability-detection/how-it-works.html>.



- [4 Wazuh, «Wazuh Decoders Syntax,» 2025. [Online]. Available:
0] <https://documentation.wazuh.com/current/user-manual/ruleset/ruleset-xml-syntax/decoders.html>.
- [4 Wazuh, «Wazuh Custom rules,» 2025. [Online]. Available:
1] <https://documentation.wazuh.com/current/user-manual/ruleset/rules/custom.html>.
- [4 Wazuh, «Wazuh Custom active response scripts,» 2025.
2] [Online]. Available:
<https://documentation.wazuh.com/current/user-manual/capabilities/active-response/custom-active-response-scripts.html>.
- [4 IBM, «IBM QRadar SIEM,» [Online]. Available:
3] <https://www.ibm.com/it-it/products/qradar-siem>.
- [4 IBM, «Rilevamento avanzato delle minacce con IBM QRadar
4] SIEM,» 2025. [Online]. Available: <https://www.ibm.com/it-it/products/qradar-siem/advanced-threat-detection>.
- [4 Cynet, «IBM QRadar: Key Modules, Features, Architecture, and
5] Limitations,» 7 Gennaio 2025. [Online]. Available:
<https://www.cynet.com/siem/ibm-qradar-key-modules-features-architecture-and-limitations/>.
- [4 Sweet Spot International, «IBM Security QRadar XDR,» 2022.
6] [Online]. Available: saas-ssi.com/ibm-security-qradar-xdr/.
- [4 ExaBeam, «Splunk SIEM: Key Features, Limitations and
7] Alternatives,» 2025. [Online]. Available:
<https://www.exabeam.com/explainers/splunk/splunk-siem-key-features-limitations-and-alternatives/>.
- [4 Splunk, « Splunk vs. IBM QRadar,» 2025. [Online]. Available:
8] https://www.splunk.com/en_us/solutions/splunk-vs-ibm-qradar.html.
- [4 Splunk, « Splunk Enterprise Security Features,» 2025. [Online].
9] Available: https://www.splunk.com/en_us/products/splunk-enterprise-security-features.html.



- [5 SecurityScorecard, «Leveraging SIEM Splunk for Enhanced
0] Cybersecurity: A Comprehensive Guide,» 4 Marzo 2024.
[Online]. Available:
[https://securityscorecard.com/blog/leveraging-siem-splunk-
for-enhanced-cybersecurity-a-comprehensive-guide/](https://securityscorecard.com/blog/leveraging-siem-splunk-for-enhanced-cybersecurity-a-comprehensive-guide/).

